

BÀI 5

Mã độc và Kỹ thuật phân tích mã độc

NỘI DUNG

Phần 1: Giới thiệu về mã độc

Phần 2: Cấu trúc và hành vi của mã độc

Phần 3: Phân tích tĩnh

Phần 4: Phân tích động

Phần 5: Kỹ thuật phòng chống và phát hiện mã độc

PHẦN 1: Giới thiệu

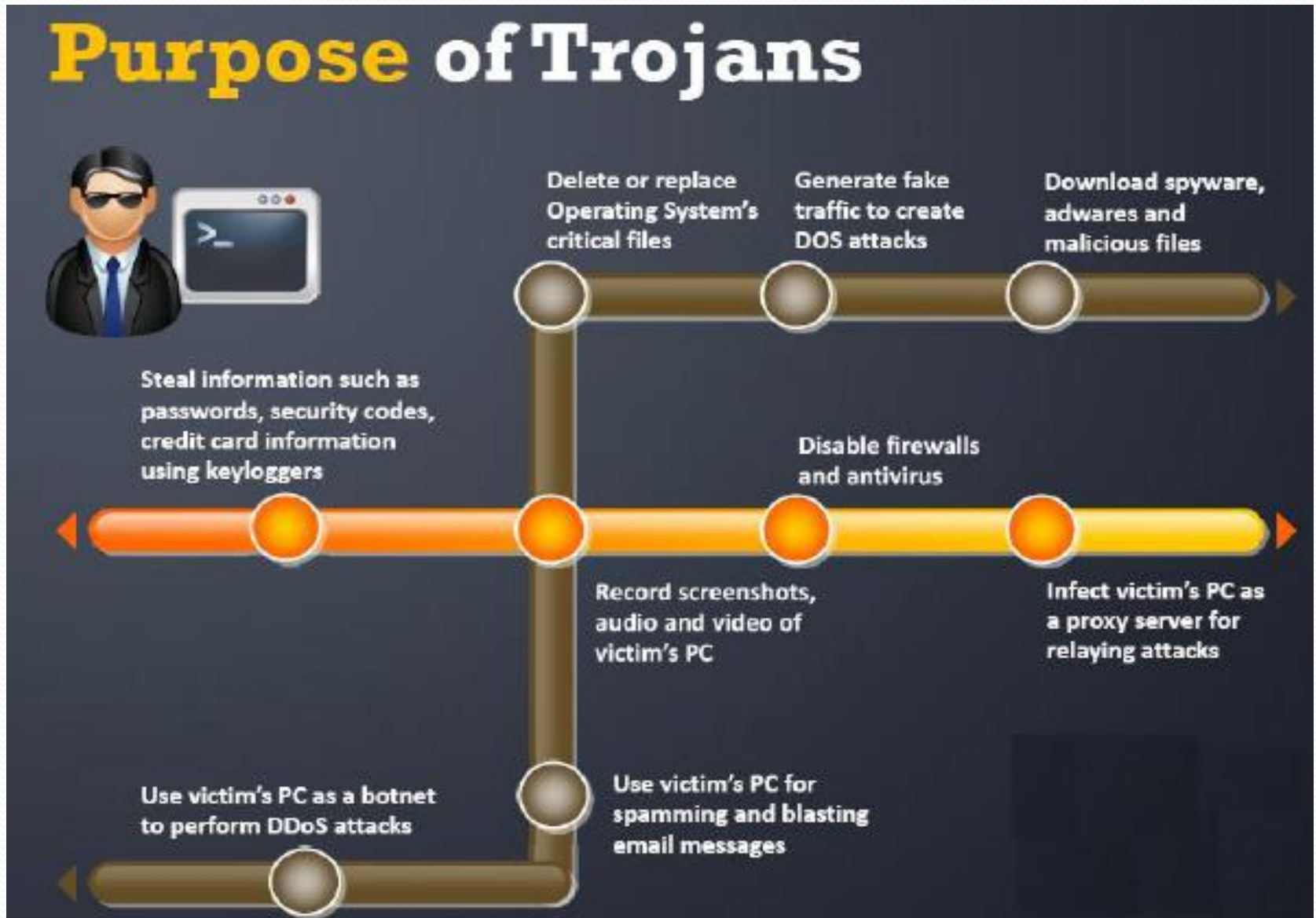
1. Định nghĩa
2. Phân loại
3. Nguồn lây nhiễm
4. Vòng đời

1. Định nghĩa

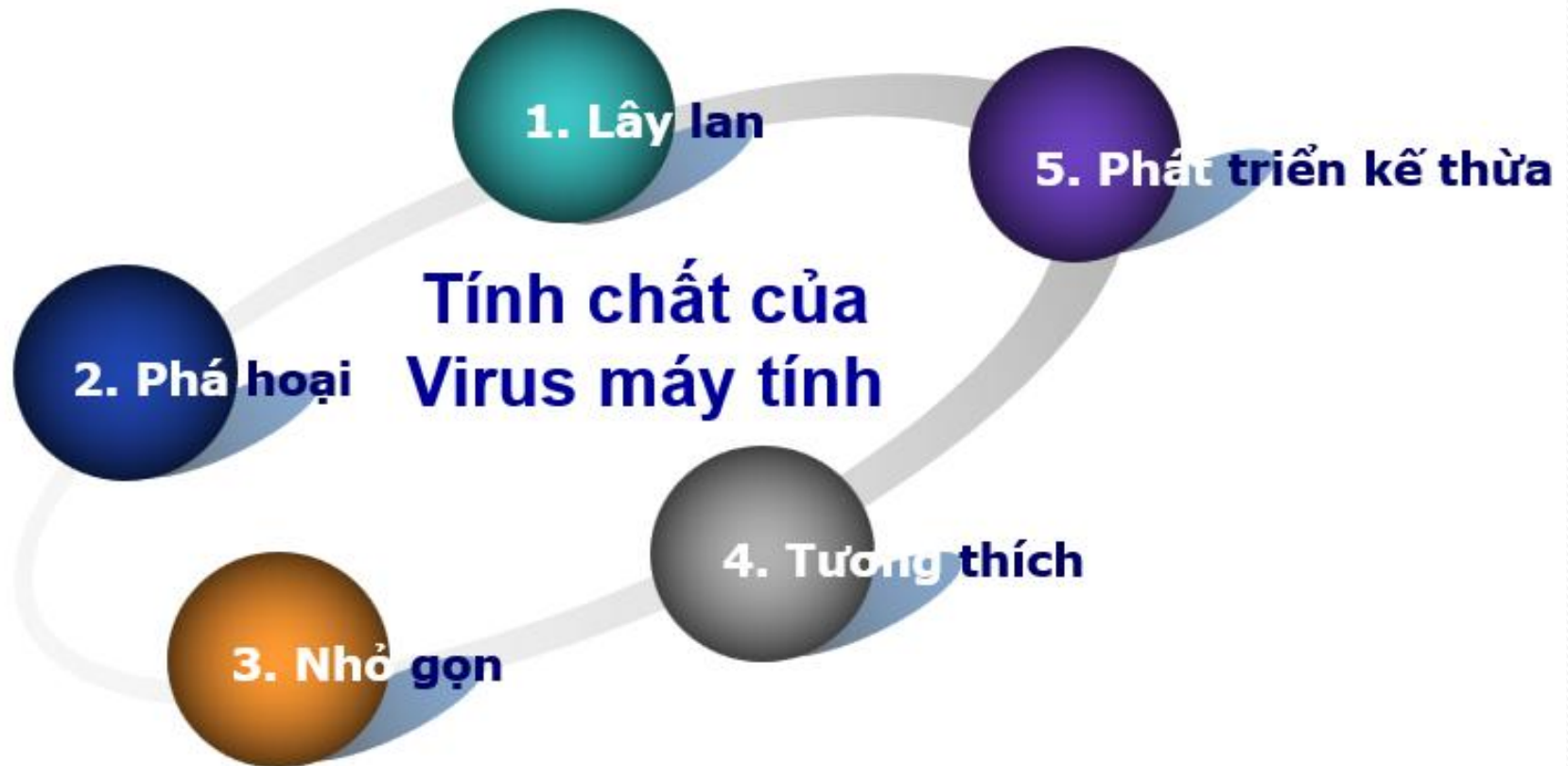
Malware là **bất kỳ chương trình, đoạn mã hoặc phần mềm** nào được lập trình với ý **đồ độc hại**, nhằm:

- Xâm nhập hệ thống
- Gây hư hại dữ liệu hoặc thiết bị
- Đánh cắp hoặc làm rò rỉ thông tin
- Theo dõi người dùng
- Chiếm quyền điều khiển từ xa
- Trục lợi kinh tế hoặc phá hoại
- Malware có thể tự lây lan hoặc không, tùy loại.

1. Định nghĩa



1. Định nghĩa



1. Định nghĩa

Công cụ viết virus

Terabit Virus Maker



2. Phân loại

Malware is a malicious software that **damages or disables computer systems** and **gives limited or full control** of the systems to the malware creator for the purpose of theft or fraud

Examples of Malware

Trojan Horse

Virus

Backdoor

Worms

Rootkit

Spyware

Ransomware

Botnet

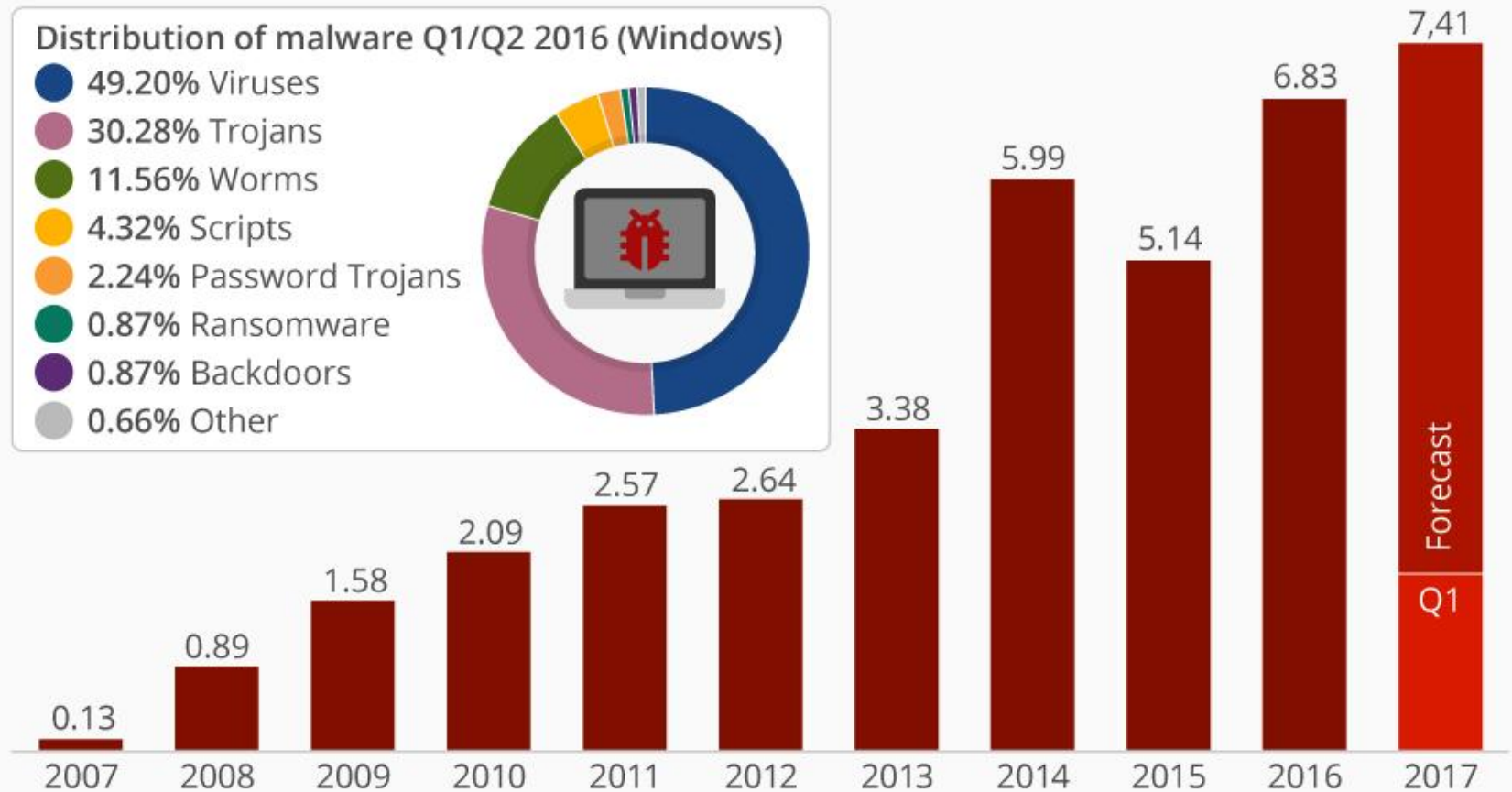
Adware

Crypter

2. Phân loại

Viruses, Worms and Trojan Horses

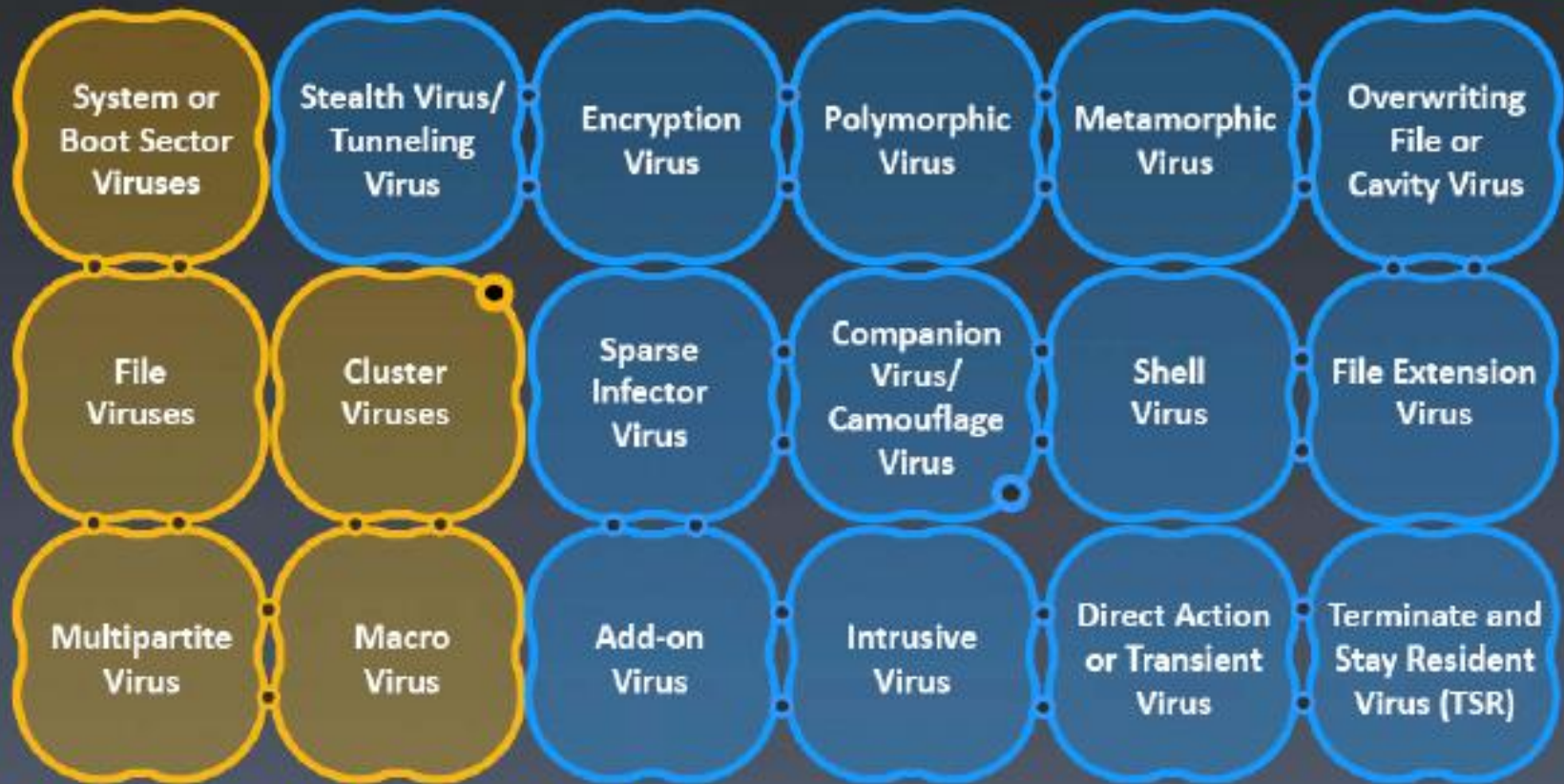
Number of new malware specimen (in millions)



2. Phân loại

Types of Viruses

How Do They Infect?



What Do They Infect?

2. Phân loại



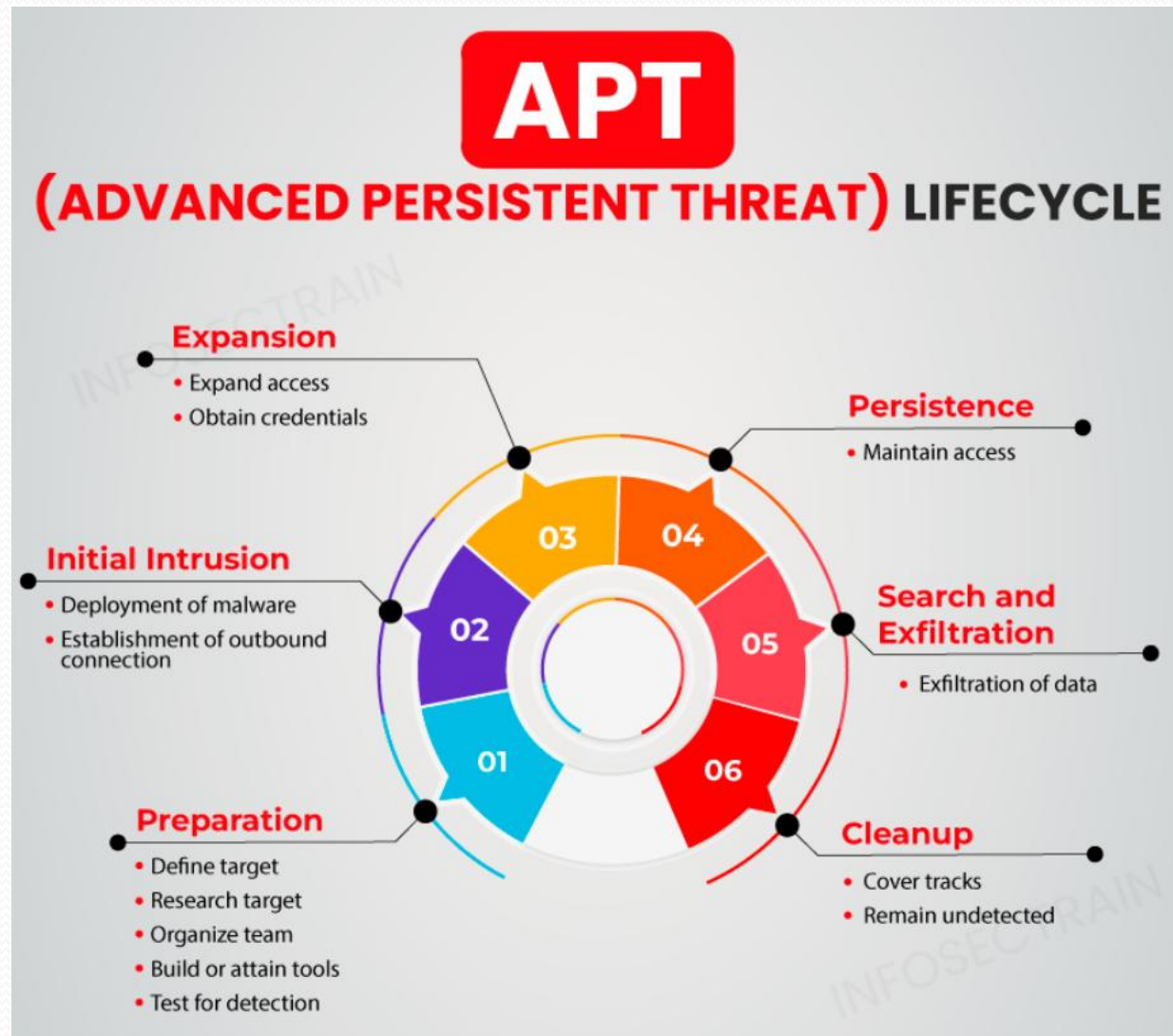
3. Nguồn lây nhiễm

- Ứng dụng Messenger.
- File đính kèm.
- Truy cập vật lý.
- Duyệt Web và Email.
- Chia sẻ file.
- Phần mềm miễn phí.
- Download tập tin, trò chơi, screensaver từ internet...



4. Vòng đời

Delivery / Infection
→ Execution →
Persistence →
Lateral Movement
→ C2 → Actions
on Objectives
(Exfiltration,
Destruction...)



4. Vòng đời

Why Do People Create **Computer Viruses**



4. Vòng đời

Trojan Virus Maker 1.2

Client Name

Darkhorse Trojan Virus Maker.1.2

Trojan Virus Maker

☐ Webcam Streaming	☐ Broken Mouse	☐ Hot Computer	☐ Virus Warnings
☐ Audio Streaming	☐ Hide Desktop icons	☐ Overloaded Files	☐ Slow Down Computer Speed
☐ Crazy Mouse	☐ ++CC Virus	☐ Hot Machine	☐ Disable Start Button
☐ Lock Window Live	☐ #C Virus	☐ Remove Documents	☐ Disable Task Manager
☐ Block All Websites	☐ Flood Large Files	☐ Remove Videos	☐ Disable CMD
☐ Disable Desktop Icons	☐ Flood Control Error	☐ Remove Music	☐ Disable Norton Antivirus
☐ Remove Desktop Background	☐ Memory User	☐ Beeping Noise	☐ Disable Avg Internet Security
☐ Disable Administration	☐ Disable Process	☐ Broken Keyboard	☐ Store Virus

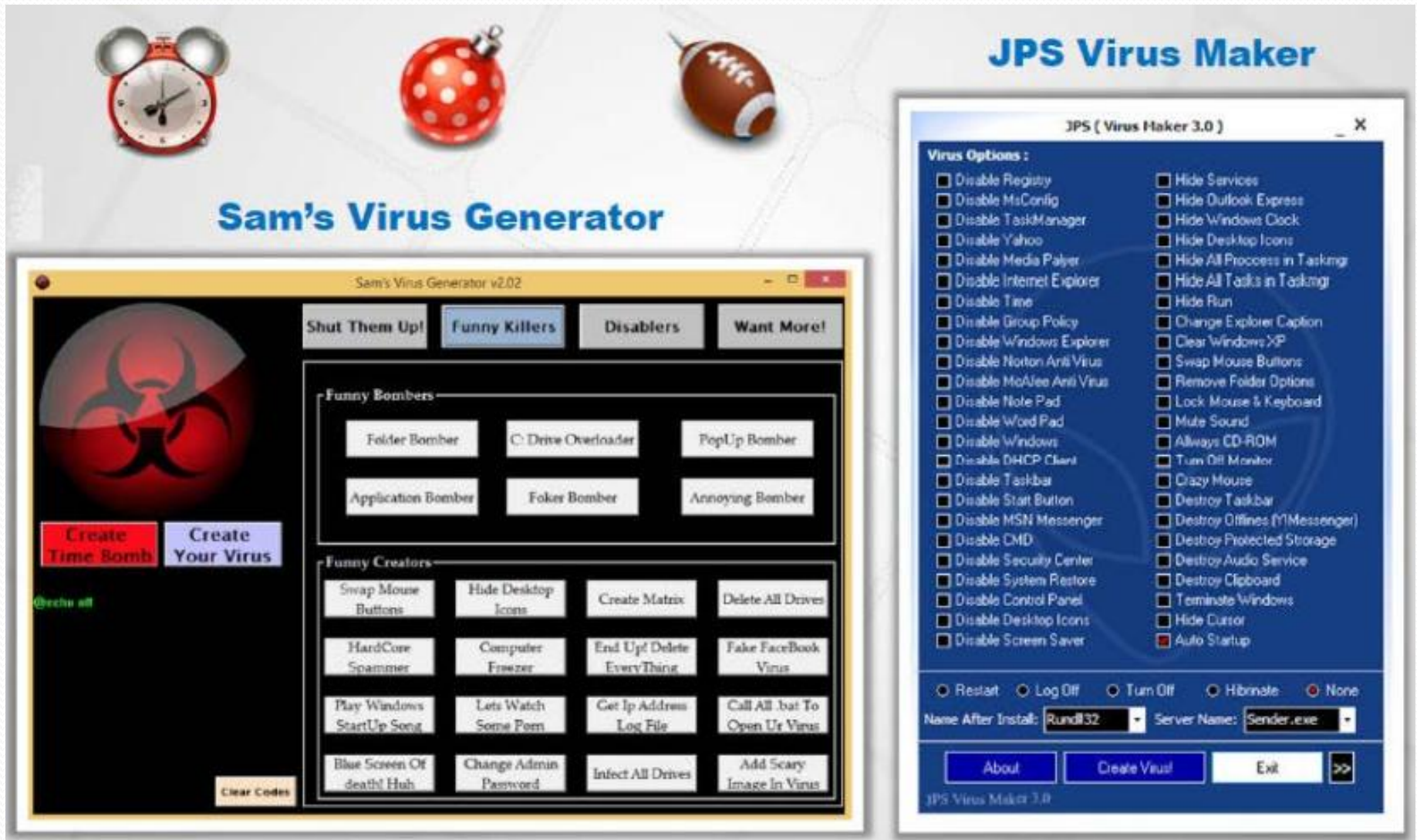
Trojan Force

☐ ShutDown Computer (1 Minute)
☐ Restart Computer (1 Minute)
☐ LogOff Computer (1 Minute)

Show Code Text

Name:

4. Vòng đời



4. Vòng đời

Internet Worm Maker Thing :- Version 4.00 :- Public Edition

INTERNET WORM MAKER THING V4

Author:

Version:

Message:

☒ Include [C] Notice

Output Path:

☐ Compile To EXE Support

Spreading Options

Startup:

- ☐ Global Registry Startup
- ☐ Local Registry Startup
- ☐ Winlogon Shell Hook
- ☐ Start As Service
- ☐ English Startup
- ☐ German Startup
- ☐ Spanish Startup
- ☐ French Startup
- ☐ Italian Startup

Payloads:

☐ Activate Payloads On Date

Day:

OR

☐ Randomly Activate Payloads

Chance of activating payloads: 1 IN CHANCE

☐ Hide All Drives

☐ Disable Task Manager

☐ Disable Keyboard

☐ Disable Mouse

☐ Message Box

Title:

Message:

Icon:

☐ Disable Regedit

☐ Disable Explorer.exe

☐ Change Reg Owner

Owner:

☐ Change Reg Organisation

Organisation:

☐ Change Homepage

URL:

☐ Disable Windows Security

☐ Disable Norton Security

☐ Uninstall Norton Script Blocking

☐ Disable Macro Security

☐ Disable Run Command

☐ Disable Shutdown

☐ Disable Logoff

☐ Disable Windows Update

☐ No Search Command

☐ Swap Mouse Buttons

☐ Open Webpage

URL:

☐ Change IE Title Bar

Text:

☐ Change Win Media Player Text

Text:

☐ Open Cd Drives

☐ Lock Workstation

☐ Download File **More?**

URL:

Save As:

☐ Execute Downloaded

☐ Print Message

Title:

Message:

Outlook Fun 1:

URL:

Sender Name:

☐ Mute Speakers

☐ Delete a File

Path:

☐ Delete a Folder

Path:

☐ Change Wallpaper

Path Or URL:

☐ CPU Monitor

☐ Change Time

Hour: **Min:**

☐ Change Date

DD: **MM:** **YY:**

☐ Play a Sound

Loop Sound:

☐ Hide Desktop

☐ Disable Malware Remove

☐ Disable Windows File Protection

☐ Corrupt Antivirus

☐ Change Computer Name

Change Drive Icon

DLL, EXE, ICO: **Index:**

☐ Add To Context Menu

☐ Change Clock Text

Text (Max 8 Chars):

☐ Hack Bit Gates **?**

☐ Keyboard Disco

☐ Add To Favorites

Name:

URL:

☐ Exploit Windows Admin Lockout

☐ Blue Screen Of Death

Infection Options:

- ☐ Infect Bat Files
- ☐ Infect Vbs Files
- ☐ Infect Vbe Files

Extras:

- ☐ Hide Virus Files

Plugins

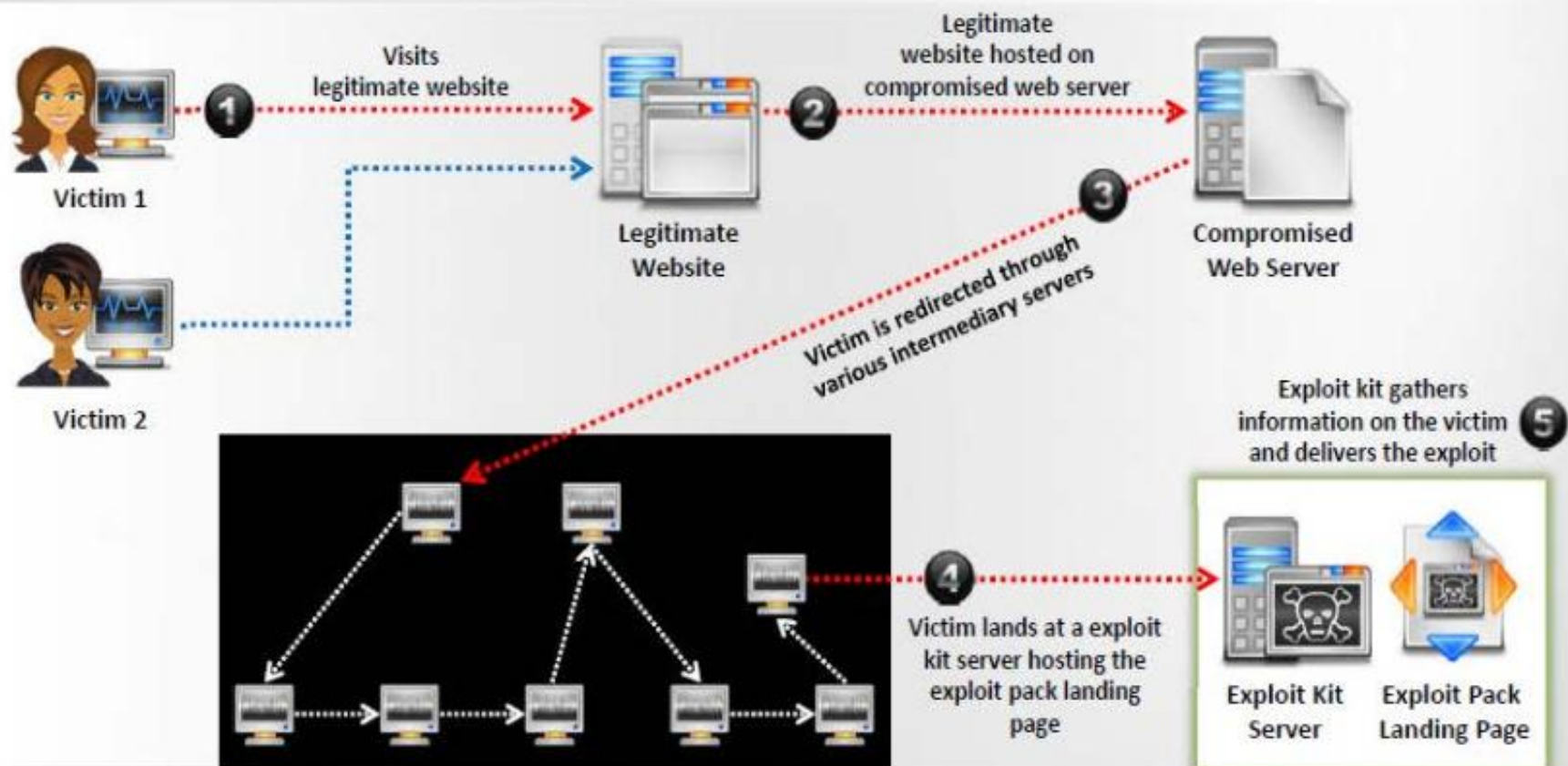
☐ Custom Code

Control Panel

If You Liked This Program Please Visit Me On <http://winstream.fallenetnetwork.com>
If You Know Anything About VBS Programming Help Support This Project By Making A Plugin (See Readme). Thanks.

4. Vòng đời

An exploit kit or crimeware toolkit is a platform to **deliver exploits and payloads** such as Trojans, spywares, backdoors, bots, buffer overflow scripts, etc. on the target system



Xâm nhập (Infection)

Cách thức phổ biến:

- Email phishing
 - File đính kèm: .docm, .xlsm, .pdf, .zip
 - Link dẫn đến trang tải malware.
 - Web compromised / drive-by download
 - Nạn nhân truy cập website đã bị chèn mã độc → trình duyệt, plugin bị khai thác lỗ hổng.
 - Thiết bị ngoại vi
 - USB, ổ cứng di động cắm vào hệ thống nội bộ.
 - Supply chain / phần mềm bị cài trojan
 - Mã độc được gài vào phần mềm hợp pháp hoặc update (Kiểu SolarWinds).
- > Phần lớn tấn công bắt đầu từ lỗi con người (social engineering).

Xâm nhập

01

Create a new Trojan packet using a **Trojan Horse Construction Kit**

02

Create a **dropper**, which is a part in a trojanized packet that installs the **malicious code** on the target system

03

Create a wrapper using **wrapper tools** to install Trojan on the victim's computer

04

Propagate the Trojan

05

Execute the dropper

06

Execute the damage routine

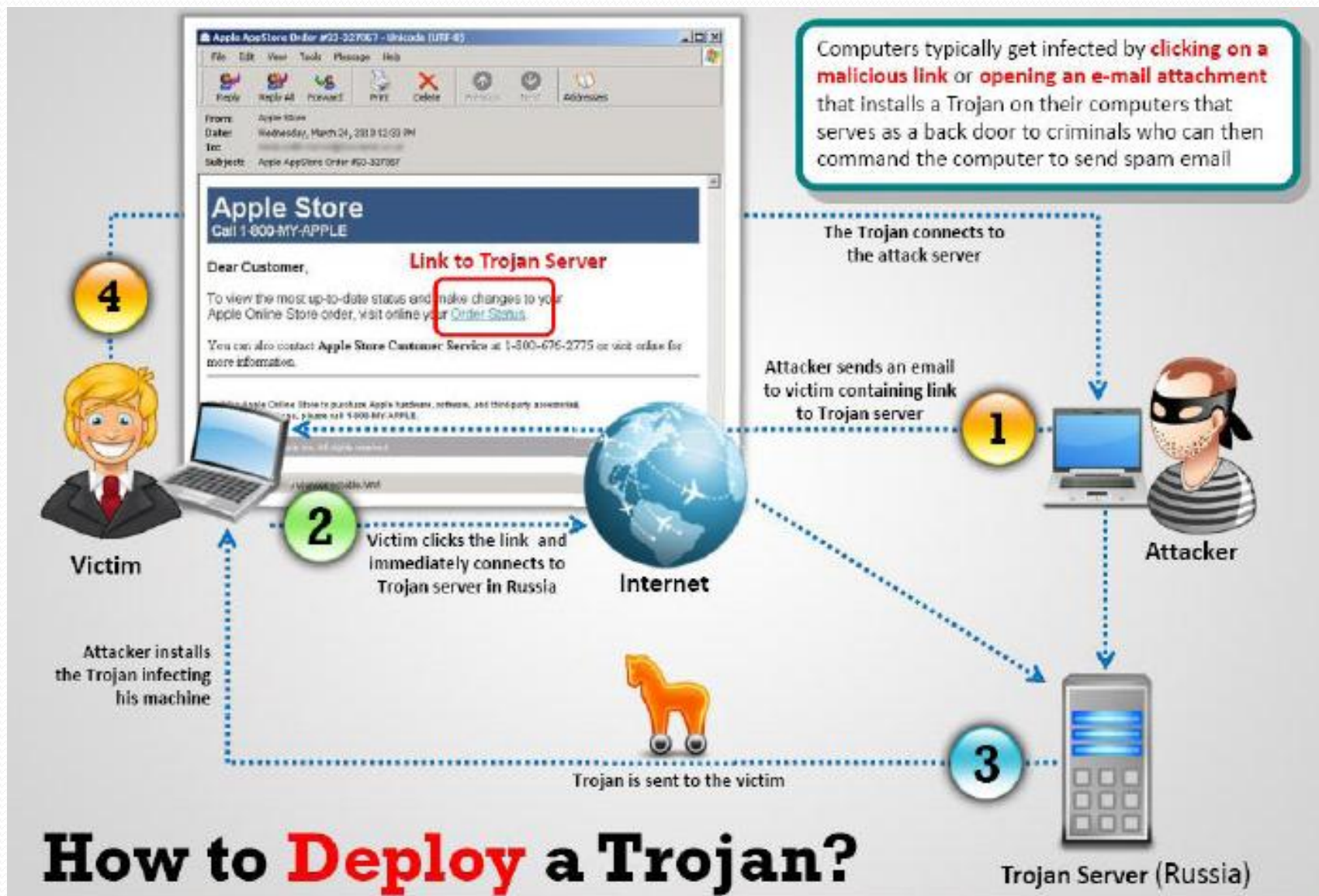


Xâm nhập

Common Ports used by Trojans

Port	Trojan	Port	Trojan	Port	Trojan	Port	Trojan
2	Death	1492	FTP99CMP	5569	Robo-Hack	21544	GirlFriend 1.0, Beta-1.35
20	Senna Spy	1600	Shivka-Burka	6670-71	DeepThroat	22222	Prosiak
21	Blade Runner, Doly Trojan, Fore, Invisible FTP, WebEx, WinCrash	1807	SpySender	6969	GateCrasher, Priority	23456	Evil FTP, Ugly FTP
22	Shaft	1981	Shockrave	7000	Remote Grab	26274	Delta
23	Tiny Telnet Server	1999	BackDoor 1.00-1.03	7300-08	NetMonitor	30100-02	NetSphere 1.27a
25	Antigen, Email Password Sender, Terminator, WinPC, WinSpy,	2001	Trojan Cow	7789	ICKiller	31337-38	Back Orifice, DeepBO
31	Hackers Paradise	2023	Ripper	8787	BackOrifice 2000	31339	NetSpy DK
80	Executor	2115	Bugs	9872-9875	Portal of Doom	31666	BOWhack
421	TCP Wrappers Trojan	2140	The Invasor	9989	INI-Killer	33333	Prosiak
456	Hackers Paradise	2155	Illusion Mailer, Nirvana	10607	Coma 1.0.9	34324	BigGluck, TN
555	Ini-Killer, Phase Zero, Stealth Spy	3129	Masters Paradise	11000	Senna Spy	40412	The Spy
666	Satanz Backdoor	3150	The Invasor	11223	Progenic trojan	40421-26	Masters Paradise
1001	Silencer, WebEx	4092	WinCrash			47262	Delta
1011	Doly Trojan	4567	File Nail 1	12223	Hack'99 KeyLogger	50505	Sockets de Troie
1095-98	RAT	4590	ICQTrojan	12345-46	GabanBus, NetBus	50766	Fore
1170	Psyber Stream Server, Voice	5000	Bubbel	12361, 12362	Whack-a-mole	53001	Remote Windows Shutdown
1234	Ultors Trojan	5001	Sockets de Troie	16969	Priority	54321	SchoolBus .69-1.11
1243	SubSeven 1.0 – 1.8	5321	Firehotcker	20001	Millennium	61466	Telecommando
1245	VooDoo Doll	5400-02	Blade Runner	20034	NetBus 2.0, Beta-NetBus 2.01	65000	Devil

Xâm nhập



Thực thi mã độc (Execution)

Mục tiêu: làm cho đoạn mã độc **chạy được** trên hệ thống.

- **Cách thực thi:**
- Người dùng **mở file đính kèm**, bấm “Enable Content / Enable Macros”.
- Trình duyệt/plugin tự động chạy mã khai thác (exploit) khi truy cập web độc hại.
- Lỗ hổng dịch vụ bị khai thác từ xa → shellcode chạy trực tiếp trên tiến trình vulnerable.
- Nhiều malware sử dụng script:
 - PowerShell, VBScript, JavaScript, batch file...

Duy trì hiện diện (Persistence)

Mục tiêu: sau khi máy **reboot** hay user logout, malware vẫn sống.

Kỹ thuật persistence phổ biến:

- Registry Run keys
 - HKCU\Software\Microsoft\Windows\CurrentVersion\Run
- Scheduled Task / Cron job
 - Tạo job chạy lại malware theo lịch hoặc khi login.
- Service / Driver độc hại
 - Tạo Windows service khởi động cùng hệ thống.
- Startup folder
 - Đặt shortcut / file trong thư mục Startup.

Người dùng tưởng đã “tắt / xóa” được malware nhưng thực ra **vẫn còn hook** ở đâu đó.

Lan truyền (Lateral Movement)

Mục tiêu: từ 1 máy bị nhiễm → **lan sang máy khác** trong cùng mạng / domain.

Dạng malware có giai đoạn này:

- **Worm:** tự quét mạng, khai thác lỗ hổng để lây lan.
- **RAT / APT malware:** hacker điều khiển thủ công, di chuyển từ máy đã bị chiếm sang máy có giá trị hơn (server database, domain controller...).

Kỹ thuật lateral movement:

- Sử dụng **tài khoản/credential đánh cắp** (Pass-the-Hash, Pass-the-Ticket).
- Exploit SMB, RDP, WinRM, SSH...
- Dùng **PSEXEC**, WMI, Remote Service Creation...
- Copy file malware sang máy khác rồi Remote Exec.

Tấn công (Exfiltration & Actions on Objectives)

Mục tiêu: đạt được kẻ tấn công muốn: **tiền, dữ liệu, phá hoại....**

Một số “mục tiêu” thường gặp:

- **Exfiltration – đánh cắp dữ liệu**
 - Thu thập file, database, tài liệu văn phòng.
 - Nén + mã hóa dữ liệu rồi gửi ra ngoài qua:
 - HTTP/HTTPS
 - DNS (DNS tunneling)
 - Email, FTP, hoặc dịch vụ cloud (Drive, Dropbox...)
- **Ransomware – mã hóa đòi tiền chuộc**
 - Mã hóa file (AES, RSA...)
 - Xóa bản shadow copy, backup cục bộ.
- **Crypto-mining – đào tiền ảo**
 - Cài miner, chiếm CPU/GPU → làm chậm hệ thống.

Tấn công (Exfiltration & Actions on Objectives)

- **Phá hoại / gián đoạn dịch vụ**
 - Xóa file, ghi đè MBR (kiểu NotPetya).
 - DDoS services.
- **Gián điệp, trộm thông tin lâu dài**
 - Keylogger
 - Screen capture
 - Theo dõi clipboard, form login...
- **Che giấu / Xóa dấu vết:**
 - Xóa log, chỉnh sửa nhật ký.
 - Tự xóa chính mình sau khi hoàn thành nhiệm vụ.
 - Sử dụng rootkit để ẩn tiến trình, file, kết nối.

PHẦN 2:

Cấu trúc và hành vi của mã độc

1. Cấu trúc file thực thi
2. Kỹ thuật che giấu và né tránh
3. Hành vi diễn hình
4. Các chỉ dấu lây nhiễm

1. Cấu trúc file thực thi

File thực thi (như **.exe**, **.dll** trên Windows) có **một số thành phần chính** giúp hệ điều hành hiểu và chạy chương trình. Khi phân tích mã độc, ta chỉ cần nắm các phần cơ bản sau:

1. Header (Phần đầu của file)

- Phần này chứa **thông tin mô tả** về file:
- File dùng để chạy trên hệ điều hành nào (Windows, 32-bit hay 64-bit).
- Điểm bắt đầu chạy của chương trình (**Entry Point**).
- Số lượng phần (section) trong file.

Khi nhìn vào header, ta biết **file có bình thường hay bị thay đổi bất thường** (dấu hiệu malware).

.

1. Cấu trúc file thực thi

2. Các Section (phần nội dung chính của file)

File thực thi được chia thành **nhiều khối (section)**, mỗi khối có nhiệm vụ riêng.

Một số section quan trọng:

.text → chứa **mã lệnh** (code) của chương trình

.data → chứa **dữ liệu**, biến...

.rdata → chứa **chuỗi ký tự, hằng số**, thông tin import

.rsrc → chứa **tài nguyên**: icon, hình ảnh, thông điệp...

👉 Malware đôi khi **giấu mã độc hoặc dữ liệu** trong các section để tránh bị phát hiện.

1. Cấu trúc file thực thi

3. Import Table (bảng các hàm mà chương trình sử dụng)

Đây là phần rất quan trọng khi phân tích mã độc.

Import Table cho biết file sử dụng **những hàm nào** của hệ điều hành, ví dụ:

- Ghi file → có thể làm hỏng hoặc thay đổi dữ liệu
- Sửa registry → dùng để **duy trì tồn tại (persistence)**
- Kết nối Internet → gửi dữ liệu ra ngoài
- Tạo tiến trình → dấu hiệu lây lan hoặc thực thi mã độc khác

👉 Nhìn vào Import Table, ta có thể **đoán sơ bộ hành vi của malware**.

1. Cấu trúc file thực thi

4. Resources (Tài nguyên)

Bao gồm:

- Icon
- Hình ảnh
- Thông điệp hiển thị
- Có thể chứa **dữ liệu ẩn** hoặc cấu hình mã độc (URL, key...)

👉 Nhà phân tích thường kiểm tra xem malware **giấu gì trong phần resource**.

2. Kỹ thuật che giấu và né tránh

Mã độc thường không muốn bị người dùng, antivirus, hay hệ thống phát hiện. Vì vậy, chúng sử dụng nhiều **kỹ thuật che giấu (obfuscation)** và **né tránh (evasion)** để tồn tại lâu hơn.

1. Packing (đóng gói)

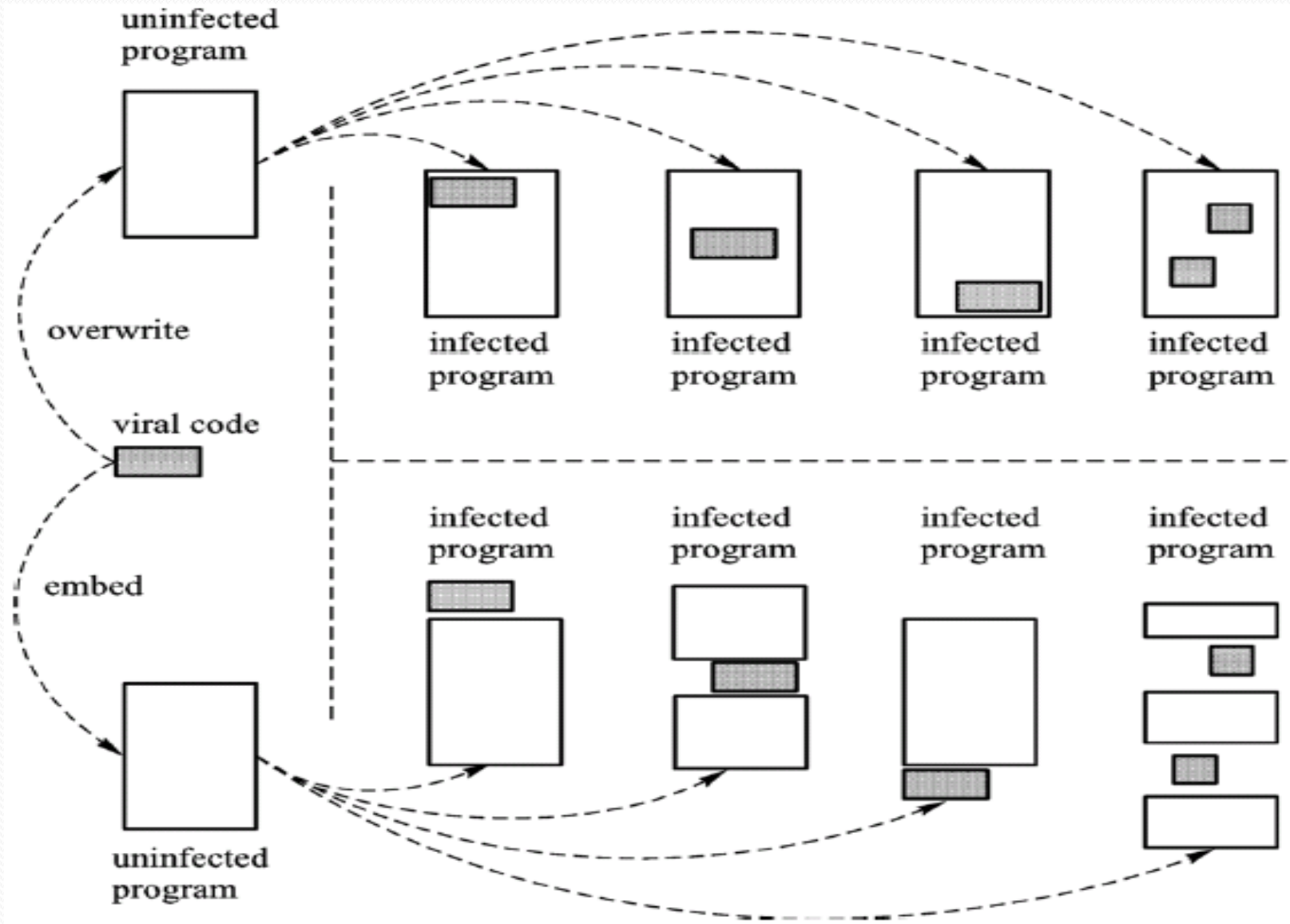
Packing là kỹ thuật **nén hoặc mã hóa** mã độc để:

- Giảm kích thước
- Làm cho mã độc **khó đọc**, khó phân tích
- Ẩn “hành vi thật” khỏi antivirus

Khi chạy, chương trình pack sẽ **giải nén chính nó** ra bộ nhớ rồi mới thực thi.

👉 Antivirus thường khó phân tích file đã pack, đặc biệt khi packer tùy chỉnh.

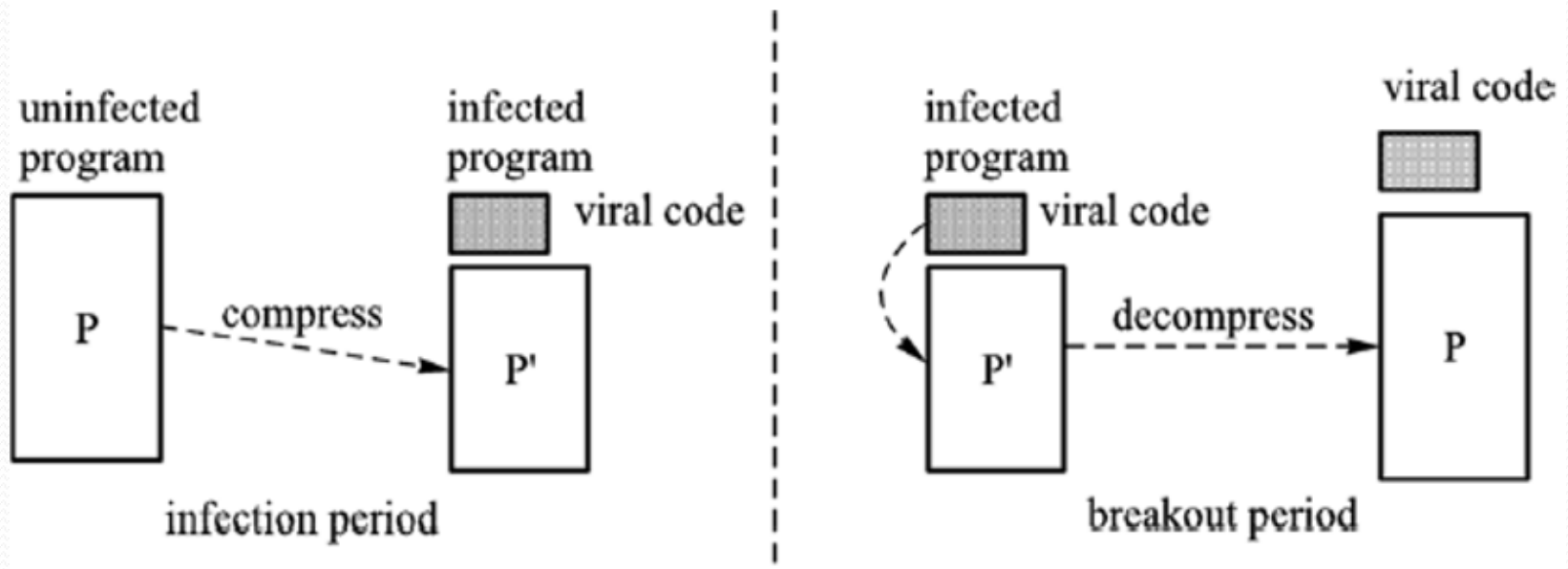
2. Kỹ thuật che giấu và né tránh



2. Kỹ thuật che giấu và né tránh

❖ Sơ đồ nén file chủ để nguy trạng sự tồn tại của Virus:

- Kiểm tra kích thước file chủ định lây nhiễm
- Nén file chủ
- Gắn đoạn mã cần lây nhiễm vào file chủ
- Có thể chèn thêm những đoạn ký tự vô nghĩa khi kích thước file chủ + virus vẫn nhỏ hơn kích thước file chủ nguyên thủy.
- Giải nén file chủ trước khi file này thực thi.



2. Kỹ thuật che giấu và né tránh

2. Obfuscation (làm rối mã)

Là cách **biến đổi mã lệnh hoặc dữ liệu** để người phân tích không hiểu.

Ví dụ:

- Làm rối chuỗi URL, IP bằng mã hóa hoặc đảo ký tự
- Thay tên biến/hàm bằng ký tự vô nghĩa
- Chèn nhiều đoạn lệnh thừa
- Viết vòng lặp phức tạp để che giấu ý đồ

Mục tiêu:

- Làm cho mã nguồn khó đọc
- Làm cho công cụ phân tích tĩnh (strings, PE Studio) **không thấy hành vi nguy hiểm**

👉 Obfuscation *không thay đổi chức năng* → chỉ làm cho mã khó hiểu hơn.

2. Kỹ thuật che giấu và né tránh

3. Anti-VM (phát hiện máy ảo)

Nhiều nhà phân tích malware dùng **máy ảo (VM)** để chạy thử mã độc. Malware biết điều này và tìm cách **không chạy trong môi trường ảo**.

Cách kiểm tra VM:

- Tìm driver hoặc phần cứng đặc trưng của VMware, VirtualBox
- Kiểm tra tên máy, tên user bất thường
- Kiểm tra số lượng CPU, RAM nhỏ (dấu hiệu VM)
- Kiểm tra tập tin/registry của các công cụ phân tích
- Nếu thấy dấu hiệu máy ảo → malware **ngừng chạy hoặc chạy hành vi giả**.

👉 Điều này khiến nhà phân tích nghĩ rằng “malware này không làm gì”, nhưng thực ra là đang né tránh.

2. Kỹ thuật che giấu và né tránh

4. Anti-Debugging (chống gỡ lỗi)

- Các công cụ như OllyDbg, x64dbg, WinDbg... giúp phân tích hoạt động của malware.

Malware dùng kỹ thuật ngăn debugger hoạt động.

Ví dụ phổ biến:

- Kiểm tra các hàm hệ thống (IsDebuggerPresent)
- Sử dụng vòng lặp vô hạn nếu phát hiện debugger
- Làm thay đổi luồng chương trình để debugger đọc sai
- Làm chương trình tự thoát khi bị debug

👉 Anti-debugging thường gặp ở trojan tinh vi, ransomware, APT malware.

2. Kỹ thuật che giấu và né tránh

5. Kỹ thuật né tránh Antivirus (AV Evasion)

- Malware còn cố gắng vượt qua phần mềm diệt virus:

Cách né tránh:

- Mã hóa payload → antivirus không thấy mã độc thật
- Chia nhỏ mã độc rồi ghép khi chạy
- Tạo chương trình “sạch” rồi tải mã độc từ Internet sau
- Sử dụng kỹ thuật “fileless malware” (chạy trong RAM, không để lại file)

👉 Khi malware không để lại dấu vết trên ổ cứng, AV truyền thống rất khó phát hiện.

2. Kỹ thuật che giấu và né tránh

Tóm tắt

Kỹ thuật	Ý tưởng	Mục đích trong malware
Packing	Nén / mã hóa file	Ẩn hành vi thật, tránh AV
Obfuscation	Làm rối mã	Khó phân tích tĩnh
Anti-VM	Phát hiện môi trường ảo	Tránh bị phân tích
Anti-Debugging	Phát hiện debugger	Ngăn phân tích động
AV Evasion	Lẩn tránh diệt virus	Duy trì sống lâu nhất

3. Hành vi điển hình

1. Tạo hoặc thay đổi file trong hệ thống

Malware thường:

- Tạo file mới trong thư mục hệ thống
- Sao chép chính nó sang nhiều vị trí
- Sửa, ghi đè hoặc mã hóa file (đặc biệt ransomware)
- Tải thêm file độc hại từ Internet

👉 Ví dụ:

Ransomware mã hóa file .docx, .xls, .pdf rồi đổi tên thành .locked.

.

3. Hành vi điển hình

2. Thay đổi Registry / cấu hình hệ thống

Mục đích: **duy trì tồn tại (persistence)** và mở đường cho hành vi khác.

Malware có thể:

- Tạo key trong:
HKCU\Software\Microsoft\Windows\CurrentVersion\Run
 - Chỉnh sửa cấu hình hệ thống
 - Vô hiệu hóa Task Manager, CMD, Regedit
 - Vô hiệu hóa Windows Defender
- 👉 Đây là dấu hiệu rất thường gặp trong trojan, backdoor.

3. Hành vi điển hình

3. Tạo tiến trình và tiêm mã (Process Injection)

Malware thường:

- Tạo tiến trình mới để chạy payload
 - “Tiêm” mã vào tiến trình hợp pháp như explorer.exe, svchost.exe
 - Che giấu hoạt động bằng cách dùng tiến trình của Windows
- 👉 Kỹ thuật này giúp malware hoạt động **ngầm**, khó bị phát hiện.

3. Hành vi điển hình

4. Thiết lập kết nối mạng (Network Communication)

Mục đích:

- Gửi dữ liệu đánh cắp ra ngoài
- Nhận lệnh từ máy chủ điều khiển (**C2 – Command & Control**)
- Tải thêm mã độc

Dấu hiệu mạng đáng chú ý:

- Liên lạc đến **IP/Domain lạ**, đặc biệt ở nước ngoài
 - Gửi nhiều request bất thường
 - Sử dụng giao thức HTTP/HTTPS, DNS, hoặc custom protocol
- 👉 Spyware, backdoor, botnet đều cần kết nối mạng.

3. Hành vi điển hình

5. Cố gắng duy trì tồn tại (Persistence Mechanisms)

Sau khi chạy, malware không muốn bị mất đi sau khi restart máy.

Các cách persistence phổ biến:

- Registry (mục Run)
- Scheduled Task (tác vụ tự chạy)
- Dịch vụ Windows (Windows Service)
- Shortcut trong thư mục Startup

👉 Dấu hiệu: Máy khởi động xong đã thấy tiến trình lạ chạy.

3. Hành vi điển hình

6. Tìm kiếm và đánh cắp thông tin

Tùy loại malware:

- **Keylogger** → ghi lại phím bấm
- **Screen capture** → chụp màn hình
- **Credential theft** → lấy mật khẩu trình duyệt, mật khẩu Wi-Fi
- **Clipboard spyware** → theo dõi nội dung copy/paste

👉 Đây là nhóm hành vi rất phổ biến trong spyware, trojan ngân hàng.

3. Hành vi điển hình

7. Phá hoại hoặc làm gián đoạn hệ thống

Hành vi nguy hiểm:

- Xóa file, xóa log
- Mã hóa dữ liệu (ransomware)
- Làm tê liệt dịch vụ
- Chiếm tài nguyên CPU/GPU để đào tiền ảo (crypto-mining)

👉 Ví dụ: Máy chậm bất thường do coin-miner chạy nền.

3. Hành vi điển hình

Tóm tắt

Nhóm hành vi	Ví dụ tiêu biểu	Ý nghĩa
Tạo file / thay đổi file	Tạo file lạ, mã hóa file	Lây nhiễm & phá hoại
Thay đổi registry	Thêm key Run	Persistence
Tạo tiến trình / injection	Inject vào <code>explorer.exe</code>	Che giấu hoạt động
Giao tiếp mạng	Liên lạc C2	Gửi dữ liệu / nhận lệnh
Đánh cắp thông tin	Keylogger, lấy mật khẩu	Mục tiêu tấn công
Phá hoại hệ thống	Xóa file, đào coin	Gây thiệt hại

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

1. Khái niệm

- **IoC** là các thông tin, dấu vết, hoặc mẫu hành vi cho thấy **hệ thống đã bị xâm nhập hoặc đang bị tấn công**.
- Là cơ sở để:
 - Phát hiện lây nhiễm sớm
 - Truy vết nguồn tấn công
 - Xây dựng luật phát hiện (IDS/IPS, SIEM, AV)

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

2. Các nhóm IoC quan trọng

A. IoC mức hệ thống (Host-based IoCs)

a. Tập tin bất thường

- File lạ xuất hiện trong thư mục quan trọng:
 - *C:\Windows\System32, Startup, Temp, /etc/init.d, /tmp, ...*
- File có tên giống file hệ thống nhưng sai lệch:
 - **svch0st.exe, expl0rer.exe**
- Tập tin mới xuất hiện cùng thời điểm sự cố.

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

b. Biến đổi registry (Windows)

- Thêm khóa khởi động cùng Windows:
 - HKCU\Software\Microsoft\Windows\CurrentVersion\Run
- Chỉnh sửa chính sách bảo mật, Windows Defender, Firewall.
- Thay đổi key liên quan đến file association (.exe, .bat).

c. Dịch vụ hoặc tiến trình bất thường

- Process chạy nền tiêu tốn CPU/RAM cao bất thường.
- Tiến trình không có mô tả, không có chữ ký số.
- Dịch vụ lạ tự động khởi động cùng máy.

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

d. Scheduled Tasks / Cron Jobs lạ

- Tạo tác vụ chạy lặp lại: tải payload, kết nối C2, ghi log...

e. Thay đổi cấu hình hệ thống

- Firewall bị tắt
- Antivirus bị vô hiệu hóa
- System Restore bị xóa điểm khôi phục

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

B. IoC mức mạng (Network-based IoCs)

a. Domain / URL khả nghi

- Liên lạc đến domain lạ, mới đăng ký, hoặc thuộc blacklist.
- Giao tiếp với máy chủ C2 qua HTTP/HTTPS, DNS tunneling.

b. Địa chỉ IP độc hại

- Gửi/nhận dữ liệu đến IP nằm trong danh sách botnet/C2.

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

c. Lưu lượng bất thường

- Tăng đột biến traffic ra ngoài (data exfiltration).
- Lưu lượng mã hóa bất thường không rõ nguồn gốc.
- Kết nối ra ngoài ở giờ không bình thường.

d. Gói tin hoặc pattern đặc thù

- Chuỗi hoặc request đặc trưng của mã độc:
 - User-Agent giả mạo
 - HTTP POST chứa dữ liệu được mã hóa base64/RC4

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

C. IoC mức tập tin (File-based IoCs)

a. Hash của mã độc

- MD5, SHA-1, SHA-256
→ Dùng để nhận diện đúng phiên bản file mã độc.

b. Chữ ký số

- File thực thi bị:
 - Không có chữ ký số
 - Dùng chứng chỉ bị revoke
 - Giả mạo publisher

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

D. IoC mức hành vi (Behavioral IoCs)

(Phát hiện bằng phân tích động)

- Payload tự giải nén, tự copy, tự nhân bản.
- Inject vào process hợp pháp (svchost.exe, explorer.exe).
- Hook API, keylogging, screen capturing.
- Kiểm tra môi trường (anti-VM, anti-debug).
- Tạo persistence (Run, Services, WMI, Scheduled Task).

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

3. Thu thập IoC bằng cách nào?

- **AV/EDR log**
- **Sysmon log**
- **SIEM** (Splunk, ELK)
- **PCAP/NetFlow**
- **Sandbox** (Cuckoo, Any.run)
- **Public feeds**: VirusTotal, Abuse.ch, MISP.

4. Các chỉ dấu lây nhiễm (Indicators of Compromise – IoCs)

4. Ứng dụng của IoC trong thực tế

- Viết **rule** cho IDS/IPS (Snort/Suricata).
- Cập nhật blacklist domain/IP.
- Tìm kiếm lây nhiễm trong hệ thống (Threat Hunting).
- Cảnh báo sớm trên SIEM.

PHẦN 3:

Phân tích mã độc tĩnh (Static Analysis)

1. Mục tiêu
2. Công cụ
3. Các bước phân tích

1. Mục tiêu của phân tích tĩnh

1. Hiểu sơ bộ về mẫu mã độc mà không cần chạy nó.
2. Nhận diện cấu trúc và đặc điểm kỹ thuật của file.
3. Phát hiện hành vi tiềm ẩn qua chuỗi và API.
4. Xác định cơ chế lây nhiễm & persistence.
5. Hỗ trợ phân tích động.
6. Tạo IOC và chữ ký phát hiện (Signature Creation).
7. Xác định khả năng liên quan tới một họ mã độc.
8. Đánh giá mức độ phức tạp & thời gian cần thiết để phân tích.

2. Công cụ phân tích tĩnh

Nhóm chính của công cụ phân tích tĩnh gồm:

1. Công cụ xem cấu trúc file (PEstudio, DIE, CFF Explorer)
2. Công cụ strings (strings, FLOSS)
3. Công cụ hash/signature (Sigcheck, HashMyFiles)
4. Disassembler/Decompiler (IDA, Ghidra, radare2)
5. Công cụ nhận diện/giải nén packer (PEiD, UPX)
6. Công cụ phân tích resource (Resource Hacker)
7. Công cụ đồ họa/luồng điều khiển (Ghidra, IDA)
8. Công cụ sandbox tĩnh/hybrid
9. Công cụ signature (YARA)

2. Công cụ phân tích tĩnh

1. Công cụ phân tích định dạng & cấu trúc file

Dùng để xem **những gì có trong file** mà *không cần chạy file*.

- **PEview** – xem header, section, import/export của PE.
- **CFF Explorer** – chỉnh sửa PE, xem cấu trúc, xem resource.
- **PEStudio** – phân tích nhanh: packed, suspicious strings, API risk.
- **ExeInfoPE** – nhận diện packer, compiler.
- **Detect It Easy (DIE)** – nhận diện packer/cryptor bằng signature.

2. Công cụ phân tích tĩnh

2. Công cụ phân tích chuỗi (Strings Analysis)

Dùng để tìm **chuỗi văn bản** trong file:

- **strings (Sysinternals)** – tìm chuỗi ASCII/Unicode.
- **FLOSS (FireEye)** – giải mã chuỗi ẩn/obfuscated strings.
- **BinText** – tìm chuỗi trong file nhị phân.

Ứng dụng:

- Phát hiện URL, IP, key, command.
- Tìm dấu vết API, lỗi debug, thông báo lỗi.

2. Công cụ phân tích tĩnh

3. Công cụ kiểm tra hash & chữ ký số

Xác thực file, tìm “bản sao” trên VirusTotal.

- **sha256sum / md5sum**
- **HashMyFiles (NirSoft)**
- **Sigcheck (Sysinternals)** – kiểm tra chữ ký số, timestamp.

2. Công cụ phân tích tĩnh

4. Công cụ phân tích mã nguồn bị dịch (Disassembly/Decompiler)

Mục tiêu: xem mã máy → mã giả lập để hiểu logic.

A. Disassembler

- **IDA Free / IDA Pro** – chuẩn công nghiệp, mạnh nhất.
- **Ghidra** – miễn phí, mạnh, có decompiler.
- **Radare2 / Cutter** – mã nguồn mở, nhiều plugin.

B. Decompiler

Chuyển mã máy → pseudo-code (C-like):

- **Ghidra Decompiler**
- **Hex-Rays (plugin của IDA)**
- **Snowman** (plugin nhiều IDE)

Ứng dụng:

- Xem chức năng mã độc.
- Tìm hàm chính: decrypt, C2 connect, persistence.

2. Công cụ phân tích tĩnh

5. Công cụ phân tích cấu trúc mã độc nén/pack

Dùng khi file bị **pack/obfuscation**:

- **UPX** – nén PE (unpack được nếu không tùy chỉnh).
- **PEiD** – nhận diện packer.
- **DIE** – phân tích packer nâng cao.
- **UnpacMe** – dịch vụ unpack online.

6. Công cụ phân tích tài nguyên (Resource Analysis)

- **Resource Hacker** – xem icon, dialog, manifest, embedded data.
- **rcedit, ResEdit** – chỉnh sửa resource.

Ứng dụng:

- Tìm file ẩn trong resource: ảnh, cấu hình C2, DLL...

.

2. Công cụ phân tích tĩnh

7. Công cụ phân tích biểu đồ và luồng điều khiển

Dùng để hình dung chương trình:

- **Ghidra** → **Function Graph**
- **IDA** → **Flow Chart**
- **Binary Ninja** – CFG trực quan.

Ứng dụng:

- Xác định hàm chính, điểm nhảy, logic điều kiện.

2. Công cụ phân tích tĩnh

8. Công cụ sandbox tĩnh / phân tích tự động (Static-oriented)

Những công cụ tự động phân tích *một phần tĩnh – một phần động*:

- **VirusTotal** – hash, strings, metadata, signature rule.
- **Hybrid-Analysis** – report chi tiết, IoCs.
- **Any.run (có phần tĩnh)** – cho biết file structure trước khi chạy.
- **Intezer** – phân loại dựa trên similarity code.

9. Công cụ luật & phân tích chữ ký (Signature analysis)

- **YARA** – tạo rule nhận diện mã độc.
- **ClamAV** – signature-based scanner.
- **KAPE, Autopsy** – forensics, tìm dấu vết file.

3. Các bước phân tích tĩnh

Các bước phân tích tĩnh gồm:

1. Chuẩn bị môi trường
2. Thu thập thông tin ban đầu
3. Kiểm tra cấu trúc file
4. Phát hiện pack/obfuscation
5. Phân tích strings
6. Phân tích import/API
7. Kiểm tra resource
8. Disassembly/Decompiler
9. Trích xuất IoCs
10. Tổng hợp & điều hướng bước tiếp

3. Các bước phân tích tĩnh

1. Chuẩn bị môi trường phân tích

- Dùng **máy ảo cách ly** (VMware/VirtualBox).
- Tắt network hoặc chỉ cho phép **Host-Only**.
- Cài công cụ cần thiết: PE Studio, DIE, IDA, Ghidra, strings, Sigcheck, Resource Hacker...
- Snapshot trước khi bắt đầu.

2. Thu thập thông tin cơ bản về file

- Tên file, kích thước, phần mở rộng.
- Hash MD5/SHA256 → đối chiếu VirusTotal.
- Kiểm tra chữ ký số (Sigcheck).
- Ghi lại thời gian nhận file và nguồn gốc.

3. Các bước phân tích tĩnh

3. Kiểm tra cấu trúc file và metadata

- **Dùng:** DIE, PEStudio, CFF Explorer
- **Kiểm tra:**
 - Type: PE/ELF/Script
 - Header, section, entry point
 - Import table / Export table
 - Compiler/packer
 - Timestamp
- **Tìm section lạ:** .textbss, .upx, .data0, .__, ...

3. Các bước phân tích tĩnh

4. Phân tích dấu hiệu packing/obfuscation

- Dùng DIE, ExeInfoPE, PEiD
- Nếu bị pack:
 - Ghi nhận packer
 - Quyết định cần **unpack thủ công** hay chuyển sang phân tích động
- Kiểm tra entropy để đo mức độ mã hóa/nén.

5. Phân tích chuỗi (Strings Analysis)

- **Dùng:** strings, FLOSS, BinText
- Tìm URL, IP, domain C2
- Tìm tên file/tên registry
- Tìm lỗi debug, thông điệp ẩn
- Tìm key mã hóa, tham số, lệnh điều khiển

3. Các bước phân tích tĩnh

6. Kiểm tra import table và API

Phân tích API để dự đoán hành vi:

- **Networking:** WinHttpOpen, InternetConnect
- **File:** CreateFile, WriteFile
- **Process:** CreateProcess, OpenProcess
- **Registry:** RegSetValue
- **Security:** CryptEncrypt, CryptGenKey
- Phát hiện hành vi: keylogging, C2, persistence...

7. Phân tích resource

Dùng: Resource Hacker

- Tìm file nhúng: ảnh, cấu hình, script, DLL.
- Kiểm tra icon, manifest — đôi khi bị giả mạo để lừa người dùng.

3. Các bước phân tích tĩnh

8. Phân tích mã máy (disassembly/decompile)

Dùng: IDA Free, Ghidra, Radare2/Cutter

- Xem **mã máy** hoặc **pseudo-code** để hiểu logic.
- Xem CFG để tìm hành vi chính.
- Tìm hàm giải mã, giải nén, kết nối mạng, persistence.
- Đặt mark những hàm quan trọng để chuẩn bị phân tích động.

9. Trích xuất IoCs

- Hash
- Chuỗi đặc trưng (URL, IP, domain)
- Import/API đáng nghi
- File name, registry key
- Các đoạn code/section bất thường
→ Dùng để viết YARA rule hoặc Snort rule.

3. Các bước phân tích tĩnh

10. Tổng hợp kết quả & quyết định bước tiếp theo

- Kết luận mức độ nguy hiểm.
- Quyết định:
 - Chuyển sang phân tích động
 - Unpack thêm
 - Viết chữ ký
 - Báo cáo cho SOC/CSIRT

PHẦN 4:

Phân tích mã độc động (Dynamic Analysis)

1. Môi trường phân tích an toàn (Sandbox)
2. Nguyên tắc chạy Malware an toàn trong lab
3. Công cụ phân tích động
4. Các bước phân tích động

1. Môi trường phân tích an toàn

1. Tại sao cần sandbox?

- Phân tích động nghĩa là **chạy thử mã độc** → nguy cơ lây lan, phá hủy hệ thống.
- Sandbox giúp cô lập hoàn toàn mã độc khỏi:
 - Máy thật
 - Mạng thật
 - Tài nguyên doanh nghiệp
- → **Đảm bảo an toàn khi quan sát hành vi.**

1. Môi trường phân tích an toàn

2. Yêu cầu của một môi trường phân tích an toàn

- **Cô lập tuyệt đối** (air-gapped hoặc network simulation).
- **Khôi phục nhanh** (snapshot máy ảo).
- **Giả lập môi trường “thật”** để tránh bị phát hiện.
- **Có đầy đủ công cụ giám sát**: process, registry, file, network.
- **Có log** để phục vụ phân tích hành vi.

1. Môi trường phân tích an toàn

3. Các loại sandbox

a. Sandbox tự động

- Cuckoo Sandbox
- CAPE Sandbox
- Any.Run
- Hybrid Analysis
- Joe Sandbox
- **Ưu điểm:** nhanh, tự động sinh báo cáo.
Nhược: mã độc nâng cao có thể **phát hiện** sandbox.

1. Môi trường phân tích an toàn

b. Sandbox thủ công (tự dựng)

Thường dùng khi phân tích nâng cao:

- **Máy ảo:**

- VMware Workstation / ESXi
- VirtualBox

- **Cấu hình:**

- Windows 7/10/11
- Snapshot ngay sau khi cài đặt
- Tắt Windows Update
- Tắt Defender
- Tắt firewall (nếu cần quan sát hành vi mạng)

- **Lợi ích:**

- Kiểm soát tuyệt đối mọi hoạt động.
- Tránh bị phát hiện dễ hơn.

1. Môi trường phân tích an toàn

4. Công cụ cần cài trong sandbox

Nhóm	Công cụ	Mục đích
Process Monitoring	Process Monitor, Process Explorer	Giám sát process, thread, file, registry
Registry/File Change	Regshot, Procmon	So sánh thay đổi trước/ sau
Network Monitoring	Wireshark, TCPView, Fakenet-NG	Bắt gói tin, giả lập C2
System info	Autoruns, Sysmon	Ghi log chi tiết
Debug	x64dbg/OllyDbg	Phân tích hành vi runtime
Others	API Monitor	Theo dõi lời gọi API

1. Môi trường phân tích an toàn

5. Cô lập mạng trong sandbox

Các cách phổ biến:

- **Host-Only Network:** mã độc không ra internet thật.
- **Internal Network:** chỉ giao tiếp giữa các VM.
- **Fakenet-NG:** mô phỏng server C2 để mã độc “nghĩ” rằng đang kết nối ra ngoài.
- **Mục tiêu:**
 - Cho phép quan sát hành vi mạng *mà không gây rủi ro thật.*

1. Môi trường phân tích an toàn

6. Kỹ thuật ẩn máy ảo để tránh bị phát hiện

- Nhiều mã độc kiểm tra:
- MAC address VMware
- Process vmtoolsd.exe
- Registry key VirtualBox
- Số lượng CPU, RAM bất thường

Tên máy: WIN7-VM, ANALYSIS-PC

- Giải pháp:
- Đặt tên máy thật
- Giả lập user folder thật
- Tăng RAM/CPU
- Cài phần mềm phổ biến (Chrome, Office...)
- Tắt Vmtools detection (một số patch)

1. Môi trường phân tích an toàn

7. Quy trình chuẩn bị sandbox

1. Tạo máy ảo mới
2. Cài Windows + update cơ bản
3. Cài công cụ phân tích
4. Cấu hình network (Host-only hoặc Fakenet)
5. Tắt update/defender
6. Snapshot → **Image sạch**
7. Dùng snapshot mới → chạy thử mẫu mã độc
8. Xem log → phân tích hành vi
9. Rollback về snapshot sạch

2. Nguyên tắc chạy Malware an toàn

Khi thực hiện phân tích động, việc chạy thử mã độc phải được thực hiện trong một môi trường được kiểm soát chặt chẽ để tránh lây lan ra hệ thống thật hoặc mạng thật. Các nguyên tắc quan trọng:

1. Cô lập tuyệt đối (Isolation)

- Luôn chạy malware trong **máy ảo (VM)**, **snapshot trước khi chạy** để có thể phục hồi sạch.
- Không bao giờ chạy trên máy thật.
- Dùng **sandbox** hoặc VM có **ống mạng cô lập (Host-only / NAT)**.

2. Nguyên tắc chạy Malware an toàn

2. Ngắt kết nối hoặc kiểm soát kết nối mạng

- Tắt hoàn toàn Internet nếu không cần thiết.
- Nếu cần kiểm tra hành vi kết nối, dùng:
 - **Fake DNS,**
 - **Inetsim,**
 - **Zeltser's Fake Internet,**
 - hoặc firewall chặn ngoài.
- Không bao giờ để malware truy cập Internet thật → nguy cơ điều khiển từ xa và lây lan.

2. Nguyên tắc chạy Malware an toàn

3. Không chia sẻ clipboard / file giữa máy thật và VM

- Tắt:
 - Shared Folder
 - Clipboard
 - Drag-Drop
- Malware có thể lợi dụng để thoát VM hoặc tự sao chép ra máy thật.

4. Tài khoản trong VM không dùng quyền Administrator (khi có thể)

- Giảm thiểu tác hại nếu malware phá hủy hệ thống.
- Tuy nhiên, một số mẫu cần quyền Admin mới hoạt động → hãy dùng quyền cao **chỉ khi cần**.

2. Nguyên tắc chạy Malware an toàn

3. Không chia sẻ clipboard / file giữa máy thật và VM

- Tắt:
 - Shared Folder
 - Clipboard
 - Drag-Drop
- Malware có thể lợi dụng để thoát VM hoặc tự sao chép ra máy thật.

4. Tài khoản trong VM không dùng quyền Administrator (khi có thể)

- Giảm thiểu tác hại nếu malware phá hủy hệ thống.
- Tuy nhiên, một số mẫu cần quyền Admin mới hoạt động → hãy dùng quyền cao **chỉ khi cần**.

2. Nguyên tắc chạy Malware an toàn

5. Tắt phần mềm bảo vệ trong VM (chỉ trong lab)

- Antivirus/EDR có thể chặn hành vi malware khiến bạn không quan sát được gì.
- Nhưng **máy thật** phải bật đầy đủ bảo vệ.

6. Snapshot trước – Xóa sạch sau (Rollback)

- Tạo snapshot ngay trước khi chạy malware.
- Sau khi phân tích → khôi phục snapshot để đảm bảo hệ thống sạch.

2. Nguyên tắc chạy Malware an toàn

7. Giữ log đầy đủ

- Ghi lại mọi hoạt động để phục vụ phân tích:
 - Process Monitor (Procmon)
 - Process Explorer
 - Wireshark
 - Regshot
 - Sysmon (tùy chọn)

8. Tuyệt đối không gửi file ra ngoài môi trường lab (trừ khi đã đóng gói an toàn)

- Nếu cần chia sẻ → nén file và đặt mật khẩu (thường dùng mật khẩu: infected).
- Không gửi qua email thông thường hoặc upload bừa bãi.

2. Nguyên tắc chạy Malware an toàn

9. Không đăng nhập tài khoản thật bên trong VM

- Không dùng tài khoản Google, Microsoft, banking...
- Tránh lộ thông tin thật nếu malware đánh cắp credential.

10. Ghi chú cẩn thận, không để sót hành vi

Ghi lại các hành vi bất thường để phục vụ phân tích tĩnh và phân tích sâu sau đó:

- File bị tạo
- Registry bị chỉnh
- Process lạ
- Kết nối mạng
- Persistence (tự khởi động lại)

3. Công cụ phân tích động

1. Công cụ quan sát tiến trình (Process Monitoring)

◆ Process Monitor (Procmon – Sysinternals)

- Theo dõi **file I/O, registry I/O, process/thread, network** (một phần).
- Giúp thấy malware tạo, sửa, xóa file nào; chỉnh sửa khóa registry gì.

◆ Process Explorer

- Hiển thị danh sách tiến trình đang chạy và các DLL được nạp.
- Giúp phát hiện tiến trình con, injected DLL, hoặc tiến trình lạ.

3. Công cụ phân tích động

2. Công cụ quan sát mạng (Network Monitoring)

◆ Wireshark

- Ghi lại toàn bộ gói tin mạng mà malware gửi/nhận.
- Giúp xem malware gọi ra server, gửi dữ liệu, liên lạc C2.

◆ TCPView / CurrPorts

- Xem các kết nối TCP/UDP đang mở.
- Theo dõi port mà malware dùng.

◆ INetSim (Internet Simulation)

- Tạo **Internet giả lập** (fake DNS, fake HTTP).
- Cho phép malware “tưởng là có mạng thật” để kích hoạt thêm hành vi.

3. Công cụ phân tích động

3. Công cụ quan sát thay đổi hệ thống

◆ Regshot

- Chụp registry trước và sau khi chạy malware.
- So sánh để tìm: persistence, thay đổi cấu hình, hành vi lây nhiễm.

◆ Sysmon (Sysinternals + log Windows Event)

- Ghi log nâng cao: tạo process, kết nối mạng, loaded libraries...
- Giúp tái hiện hành vi chạy malware rất chi tiết.

3. Công cụ phân tích động

4. Công cụ giám sát file và dịch vụ

◆ FileActivityWatch / FolderChangesView

- Theo dõi xem thư mục nào bị chỉnh sửa.
- Hữu ích khi malware tự sao chép, tạo file log, tải payload mới.

◆ Autoruns

- Phát hiện và kiểm soát các mục **khởi động cùng Windows** (Persistence).
- Dùng để xem malware có tự cài startup hay không.

3. Công cụ phân tích động

5. Công cụ giám sát API và hành vi nâng cao

◆ API Monitor

- Theo dõi các lời gọi API (Windows API, Network API).
- Cực hữu ích để xem malware dùng kỹ thuật gì:
 - Anti-debug
 - Process injection
 - Hooking
 - Download payload

◆ OllyDbg / x64dbg (chỉ dùng nhẹ)

- Không phải phân tích tĩnh hoàn toàn → dùng để theo dõi chạy từng bước.
- Hữu ích khi muốn xem luồng xử lý chính của malware.

3. Công cụ phân tích động

6. Công cụ sandbox tự động hóa

◆ Cuckoo Sandbox

- Sandbox mã nguồn mở phổ biến nhất.
- Tự động chạy malware, thu log, phân tích hành vi và tạo report.

◆ Any.Run

- Sandbox trực quan → xem malware chạy theo thời gian thực.
- Hỗ trợ xem Process Tree, Network, Registry.

◆ Hybrid Analysis / Joe Sandbox

- Cho phép upload mẫu (cần trọng).
- Tự động phân tích sâu.

3. Công cụ phân tích động

7. Công cụ phân tích lưu lượng lên lút

- ♦ **Fakenet-NG**
- Giả lập mạng, DNS, HTTP, SMTP, SSL cho malware.
- Rất tốt khi malware cần mạng để kích hoạt thêm hành vi.

8. Bộ công cụ Sysinternals tổng hợp

Rất quan trọng, gồm nhiều công cụ “kinh điển”:

Procmon, Procexp, Autruns, TCPView, Sigcheck, Strings

4. Các bước phân tích động

1. Chuẩn bị môi trường an toàn

- Sử dụng **VM cách ly**, không chia sẻ clipboard.
- Snapshot trước khi chạy.
- Kiểm tra các công cụ monitor đã bật (Procmon, Wireshark...).
- Kích hoạt **FakeNet/INetSim** nếu cần Internet giả lập.

4. Các bước phân tích động

2. Ghi nhận trạng thái hệ thống ban đầu

- Chụp snapshot registry với **Regshot**.
- Ghi lại danh sách process hiện tại.
- Ghi lại network connections đang mở.
- Chụp ảnh ổ đĩa hoặc tạo baseline hash nếu cần.

4. Các bước phân tích động

3. Chạy mẫu malware trong môi trường kiểm soát

- Chạy file dưới dạng user bình thường (không admin trừ khi cần).
- Quan sát realtime: process mới, file mới, kết nối mạng.
- Nếu malware không hoạt động → kích hoạt bằng tham số / URL giả lập.

4. Các bước phân tích động

4. Theo dõi hoạt động hệ thống

- **Process**

- Quan sát tiến trình cha – con.

- **File system**

- File mới, file bị mã hóa, thư mục bị thay đổi.

- **Registry**

- Thêm khóa autostart → persistence.
- Sửa đổi policy, firewall, defender.

- **Network**

- Kết nối TCP/UDP, HTTP request, DNS query.
- C2 communication → phân tích IOC.

- **API / hành vi nâng cao**

- Kiểm tra anti-debug, anti-VM, sleep, encryption.

4. Các bước phân tích động

5. Quan sát trong thời gian thực (live monitoring)

- **Procmon**: theo dõi file/registry.
- **Procexp**: tiến trình, DLL.
- **Wireshark/Fakenet**: gói tin mạng.
- **Sysmon**: log tổng hợp.
- **API Monitor**: hàm API được gọi.

4. Các bước phân tích động

6. Ghi nhận sự thay đổi sau khi chạy

- Dùng **Regshot** để so sánh registry trước/sau.
- Liệt kê file mới hoặc file sửa đổi.
- Xuất log Procmon để phân tích sâu.
- Ghi lại mọi IOC thu được:
 - URL, IP, domain
 - Hash file
 - Mutex
 - Registry key
 - File path

4. Các bước phân tích động

7. Phân tích và kết luận hành vi

- Malware làm gì?
 - Tự copy? Tải payload? Mã hóa file?
- Malware thuộc loại nào?
(Trojan/RAT/Keylogger/Ransomware...)
- Mục tiêu tấn công?
- Kỹ thuật persistence?
- Hành vi lây lan?

8. Tạo báo cáo

- Tổng hợp log và IOC.
- Mô tả **Process Tree**.
- Tóm tắt hành vi chính.
- Đưa ra khuyến nghị phát hiện và ngăn chặn.

PHẦN 5: Kỹ thuật phòng chống và phát hiện mã độc

1. Phòng ngừa ở cấp độ người dùng
2. Phòng vệ ở cấp độ hệ thống
3. Phòng vệ ở cấp độ mạng
4. Phát hiện mã độc
5. Kỹ thuật phản ứng

1. Phòng ngừa ở cấp độ người dùng

◆ Thói quen sử dụng an toàn

- Không mở file đính kèm lạ, link trong email không rõ nguồn gốc.
- Không cài phần mềm crack, keygen.
- Cập nhật hệ điều hành và ứng dụng thường xuyên.

◆ Quản lý mật khẩu & xác thực

- Sử dụng **mật khẩu mạnh**, MFA.
- Tránh lưu mật khẩu trong trình duyệt.

◆ Sao lưu định kỳ

- Backup 3-2-1: 3 bản → 2 thiết bị → 1 bản offline.
- Ngăn chặn mất dữ liệu khi bị ransomware.

2. Phòng vệ ở cấp độ hệ thống

- ◆ **Hệ điều hành & ứng dụng**
 - Cập nhật bản vá lỗ hổng (Patch Management).
 - Vô hiệu hóa macro Office khi không cần.
 - Bật Windows Defender / Endpoint Protection.
- ◆ **Quản lý quyền (Privilege Management)**
 - Sử dụng tài khoản thường (User), tránh dùng Admin.
 - Áp dụng nguyên tắc Least Privilege.
- ◆ **Hardening hệ thống**
 - Tắt dịch vụ không cần thiết.
 - Giới hạn RDP, SMB; bật firewall.

3. Phòng vệ ở cấp độ mạng

◆ Firewall / IDS / IPS

- Ngăn chặn lưu lượng bất thường.
- IDS (Snort/Suricata) phát hiện dấu hiệu C2, mã hóa bất thường.
- IPS chặn khai thác lỗ hổng (exploit).

◆ DNS Filtering

- Chặn domain độc hại hoặc nằm trong blacklist.
- Ngăn malware kết nối C2.

◆ Segmentation (chia mạng)

- Giảm mức độ lan truyền lateral movement.

4. Phát hiện mã độc

A. Phát hiện dựa trên chữ ký (Signature-based)

- So khớp hash, chuỗi, API, mẫu byte.
- Ưu điểm: nhanh, chính xác.
- Nhược: không phát hiện biến thể/obfuscation.

B. Phát hiện hành vi (Behavior-based Detection)

- Phân tích hành vi:
 - Tạo file lạ
 - Tiến trình bất thường
 - Kết nối mạng C2
 - Injection, persistence
- Ưu điểm: phát hiện zero-day.
- Nhược: dễ gây false positive.

4. Phát hiện mã độc

C. Phát hiện bằng Machine Learning / AI

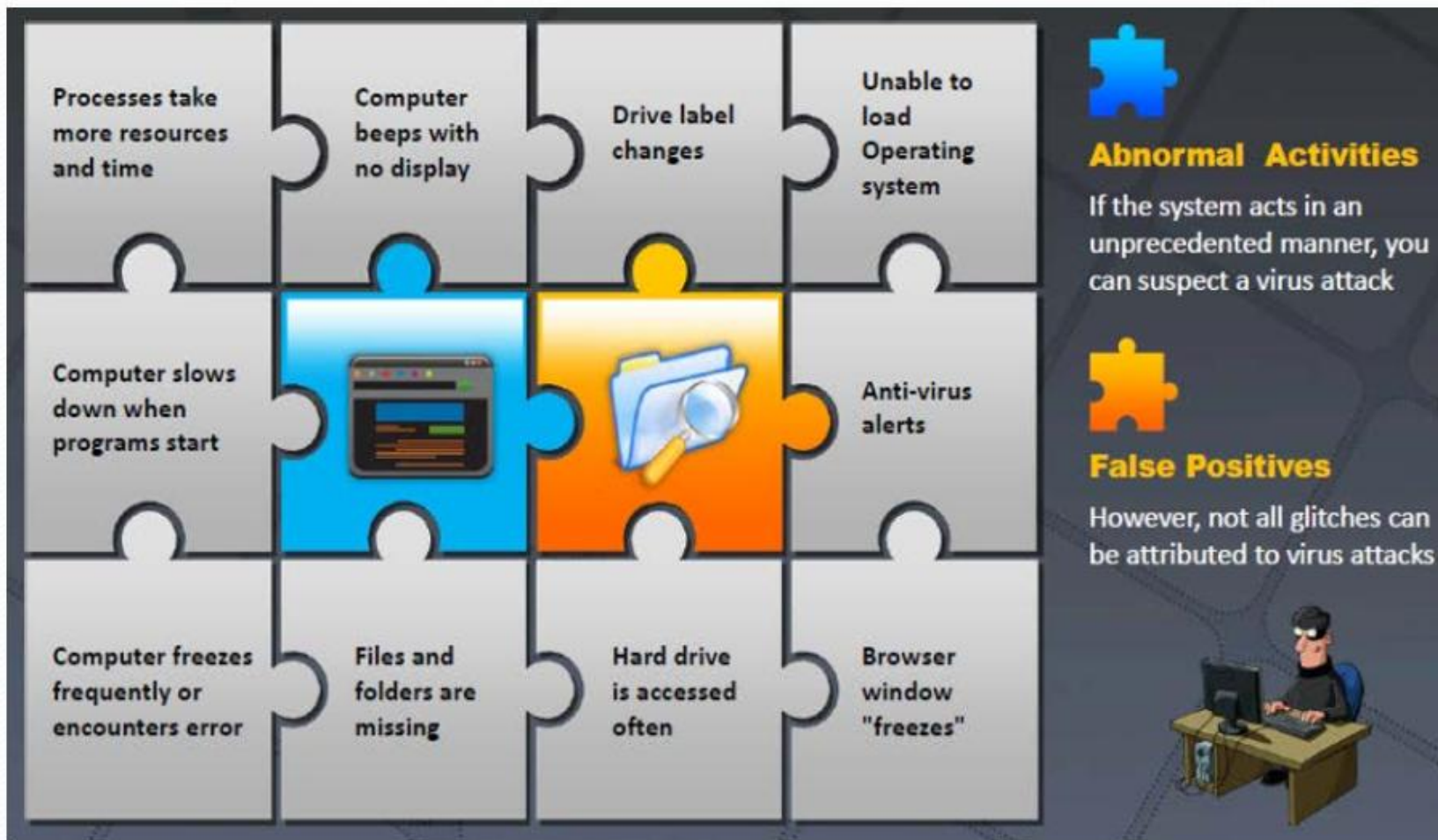
- Học đặc trưng từ file (static + dynamic).
- Phát hiện biến thể, malware chưa từng thấy.
- ML dùng trong EDR/XDR hiện đại.

D. Phát hiện dựa trên Sandbox

- Chạy thử file trong môi trường ảo → phân tích hành vi.
- Phát hiện ransomware, trojan, dropper.

4. Phát hiện mã độc

Indications of Virus Attack



4. Phát hiện mã độc

How to **Detect** Trojans



Scan for suspicious **OPEN PORTS**



Scan for suspicious **RUNNING PROCESSES**



Scan for suspicious **REGISTRY ENTRIES**



Scan for suspicious **DEVICE DRIVERS**
installed on the computer



Scan for suspicious **WINDOWS SERVICES**



Scan for suspicious **STARTUP PROGRAMS**



Scan for suspicious **FILES** and **FOLDERS**



Scan for suspicious **NETWORK ACTIVITIES**



Scan for suspicious modification to
OPERATING SYSTEM FILES



Run Trojan **SCANNER** to detect Trojans



4. Phát hiện mã độc

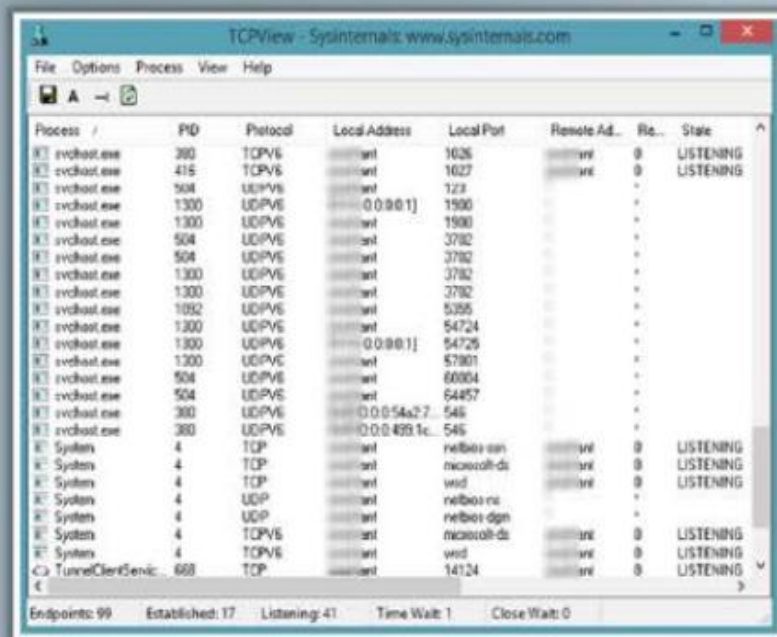
Port Monitoring Tools: **TCPView** and **CurrPorts**

TCPView

TCPView show detailed listings of all **TCP** and **UDP endpoints** on your system, including the local and remote addresses and state of **TCP connections**

CurrPorts

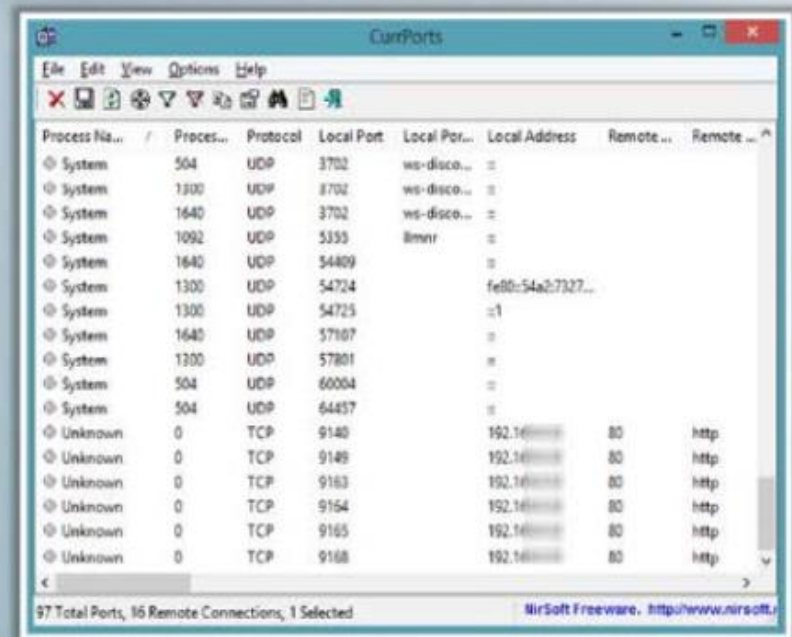
CurrPorts is **network monitoring** software that displays the list of all currently opened **TCP/IP** and **UDP** ports on your local computer



TCPView - Sysinternals: www.sysinternals.com

Process	PID	Protocol	Local Address	Local Port	Remote Address	Remote Port	State
svchost.exe	360	TCPV6	*	1626	*	0	LISTENING
svchost.exe	416	TCPV6	*	1627	*	0	LISTENING
svchost.exe	504	UDPV6	*	123	*	0	
svchost.exe	1300	UDPV6	0.0.0.0	1900	*	0	
svchost.exe	1300	UDPV6	*	1900	*	0	
svchost.exe	504	UDPV6	*	3702	*	0	
svchost.exe	504	UDPV6	*	3702	*	0	
svchost.exe	1300	UDPV6	*	3702	*	0	
svchost.exe	1300	UDPV6	*	3702	*	0	
svchost.exe	1092	UDPV6	*	5356	*	0	
svchost.exe	1300	UDPV6	*	54724	*	0	
svchost.exe	1300	UDPV6	0.0.0.0	54725	*	0	
svchost.exe	1300	UDPV6	*	57801	*	0	
svchost.exe	504	UDPV6	*	60004	*	0	
svchost.exe	504	UDPV6	*	64457	*	0	
svchost.exe	360	UDPV6	0.0.0.0	546	*	0	
svchost.exe	360	UDPV6	0.0.0.0	546	*	0	
System	4	TCP	netbios-ssn	*	*	0	LISTENING
System	4	TCP	netbios-ssn	*	*	0	LISTENING
System	4	TCP	netbios-ssn	*	*	0	LISTENING
System	4	UDP	netbios-ns	*	*	0	
System	4	UDP	netbios-dgm	*	*	0	
System	4	TCPV6	netbios-ssn	*	*	0	LISTENING
System	4	TCPV6	netbios-ssn	*	*	0	LISTENING
TunnelClientGenic	668	TCP	*	14124	*	0	LISTENING

Endpoints: 99 Established: 17 Listening: 41 Time Wait: 1 Close Wait: 0



CurrPorts

Process Name	Process ID	Protocol	Local Port	Local Port Name	Local Address	Remote Address	Remote Port
System	504	UDP	3702	ws-disco...	*	*	*
System	1300	UDP	8702	ws-disco...	*	*	*
System	1640	UDP	3702	ws-disco...	*	*	*
System	1092	UDP	5356	limn...	*	*	*
System	1640	UDP	54409		*	*	*
System	1300	UDP	54724		fe80::54a2:7327...	*	*
System	1300	UDP	54725		::1	*	*
System	1640	UDP	57107		*	*	*
System	1300	UDP	57801		*	*	*
System	504	UDP	60004		*	*	*
System	504	UDP	64457		*	*	*
Unknown	0	TCP	9140		192.168.1.1	80	http
Unknown	0	TCP	9149		192.168.1.1	80	http
Unknown	0	TCP	9163		192.168.1.1	80	http
Unknown	0	TCP	9164		192.168.1.1	80	http
Unknown	0	TCP	9165		192.168.1.1	80	http
Unknown	0	TCP	9168		192.168.1.1	80	http

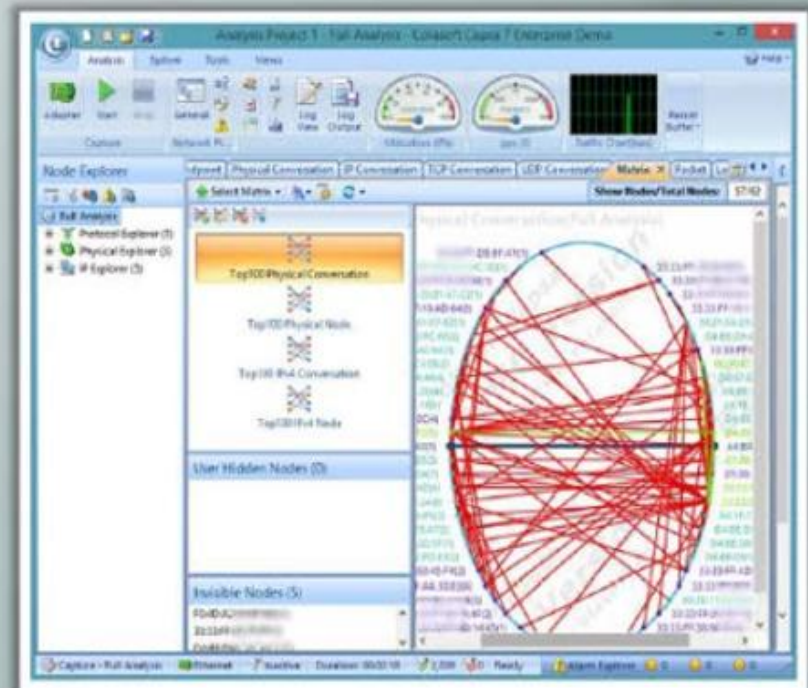
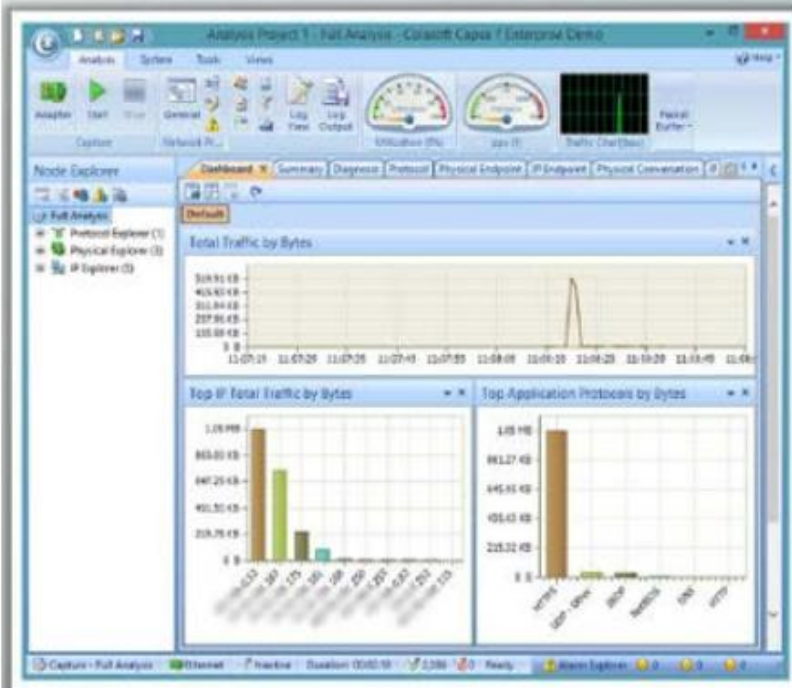
97 Total Ports, 16 Remote Connections, 1 Selected

NirSoft Freeware: <http://www.nirsoft.net>

4. Phát hiện mã độc

Detecting Trojans and Worms with Capsa Network Analyzer

Capsa is an intuitive network analyzer, which provides detailed information to help check if there are any **Trojan activities on a network**



5. Kỹ thuật phản ứng

- ◆ **Cô lập endpoints bị nhiễm**
 - Ngắt khỏi mạng để tránh lây lan.
- ◆ **Xóa bỏ mã độc**
 - Sử dụng AV/EDR hoặc thủ công tùy mức độ.
- ◆ **Khôi phục dữ liệu**
 - Dùng backup sạch, không trả tiền chuộc ransomware.
- ◆ **Viết báo cáo hậu sự cố**
 - Bài học kinh nghiệm.
 - Cập nhật rule, signature, policy.

5. Kỹ thuật phản ứng

Trojan Countermeasures

	Avoid opening email attachments received from unknown senders		Install patches and security updates for the operating systems and applications
	Block all unnecessary ports at the host and firewall		Scan CDs and DVDs with antivirus software before using
	Avoid accepting the programs transferred by instant messaging		Restrict permissions within the desktop environment to prevent malicious applications installation
	Harden weak, default configuration settings and disable unused functionality including protocols and services		Avoid typing the commands blindly and implementing pre-fabricated programs or scripts
	Monitor the internal network traffic for odd ports or encrypted traffic		Manage local workstation file integrity through checksums, auditing, and port scanning
	Avoid downloading and executing applications from untrusted sources		Run host-based antivirus , firewall, and intrusion detection software

5. Kỹ thuật phản ứng

Virus and Worms Countermeasures

Install **anti-virus** software that detects and removes infections as they appear

01

Pay attention to the **instructions** while downloading files or any programs from the Internet

03

Avoid opening the attachments received from an **unknown sender** as viruses spread via e-mail attachments

05

Schedule **regular scans** for all drives after the installation of anti-virus software

07



02

Generate an **anti-virus policy** for safe computing and distribute it to the staff

04

Update the anti-virus software regularly

06

Possibility of virus infection may corrupt data, thus regularly maintain **data back up**

08

Do not accept disks or programs without checking them first using a **current version** of an anti-virus program



5. Kỹ thuật phản ứng

Virus and Worms Countermeasures

Ensure the **executable code** sent to the organization is approved

1

Do not boot the machine with **infected** bootable system disk

2

Know about the **latest virus** threats

3

Check the **DVDs** and **CDs** for virus infection

4

Ensure the **pop-up blocker** is turned on and use an Internet firewall

5

Run disk clean up, registry scanner and **defragmentation** once a week

6

Turn on the **firewall** if the OS used is Windows XP

7

Run **anti-spyware** or **adware** once in a week

8

Do not open the files with more than one **file type extension**

9

Be cautious with the files being sent through the **instant messenger**

10

BÀI TẬP